0198. ○ △ × 20.2회.산기

보안 관리자는 관리하는 유닉스 서버의 환경설정파일을 확인한 결과 보기와 같이 접근권한(permission)이 설정된 것을 확인하였다. 각각의 질문에 답하시오.

보기

운영체제 : UNIX
환경설정파일 : .login , .profile
환경설정파일 접근권한 : rwxrwxrwx

1) 8진수 표기법으로 .login 환경설정파일에 대해 일반 사용자는 읽기 권한만 가지도록 명령어를 작성하시오.
2) 문자 표기법과 - 연산자를 이용하여 .profile 환경설정파일에 대해 소유자를 제외하고 모두 쓰기 권한이 제거되도록 명령어를 작성하시오.
3) .profile 환경설정파일의 소유자 정보를 another_admin으로 변경하도록 명령어를 작성하시오.
4) 소유자 및 접근권한을 변경한 환경설정파일의 변경 내역을 확인할 수 있는 명령어를 작성하시오.

정답 및 해설

1) chmod 774 .login
2) chmod go-w .profile

```
[algisa@CentOS9S2 ~]$ ls -l .login .profile
-rwxrwxrwx 1 algisa soc 0 Dec 29 20:56 .login
-rwxrwxrwx 1 algisa soc 0 Dec 29 20:56 .profile
[algisa@CentOS9S2 ~]$
[algisa@CentOS9S2 ~]$ chmod 774 .login
[algisa@CentOS9S2 ~]$ ls -l .login
-rwxrwxr-- 1 algisa soc 0 Dec 29 20:56 .login
[algisa@CentOS9S2 ~]$
[algisa@CentOS9S2 ~]$ chmod go-w .profile
[algisa@CentOS9S2 ~]$ ls -l .profile
-rwxr-xr-x 1 algisa soc 0 Dec 29 20:56 .profile
```

3) chown another_admin .profile

```
[root@CentOS9S2 /home/algisa]# ls -l .profile
-rwxr-xr-x 1 algisa soc 0 Dec 29 20:56 .profile
[root@CentOS9S2 /home/algisa]#
[root@CentOS9S2 /home/algisa]# chown another_admin .profile
[root@CentOS9S2 /home/algisa]# ls -l .profile
-rwxr-xr-x 1 another_admin soc 0 Dec 29 20:56 .profile
```

4) ls -l(소문자 L) .login .profile

0199. ○ △ × 24.4회.산기

유닉스 시스템 보안 관리자는 시스템 파일을 보호하기 위해 접근권한을 변경하려고 한다. 다음 각 질문의 요구사항을 chmod 명령어로 작성하시오.

시스템 파일	요구사항
▪ 운영체제 : 유닉스 ▪ 파일명 : sysbin ▪ 접근권한 : rwxrwxrwx	1) 문자열 모드(Symbolic mode)로 -연산자를 이용하여 sysbin 파일의 그룹과 나머지 사용자에게 읽기 권한만 설정하시오. 2) 문자열 모드(Symbolic mode)로 =연산자를 이용하여 sysbin 파일의 그룹과 나머지 사용자에게 읽기 권한만 설정하시오. 3) 8진법 모드(Octal mode)를 이용하여 sysbin 파일의 접근권한을 rwxr-xr--로 설정하시오.

정답 및 해설

1) chmod go-wx sysbin 또는 chmod g-wx,o-wx sysbin

```
[root@Fedora11 ~]# ls -l sysbin
-rwxrwxrwx 1 root root 0 2024-11-24 03:16 sysbin
[root@Fedora11 ~]#
[root@Fedora11 ~]# chmod g-wx, o-wx sysbin
chmod: invalid mode: `g-wx,'
Try `chmod --help' for more information.
[root@Fedora11 ~]#
[root@Fedora11 ~]# chmod g-wx,o-wx sysbin
[root@Fedora11 ~]# ls -l sysbin
-rwxr--r-- 1 root root 0 2024-11-24 03:16 sysbin
```

콤마(,)를 이용한 권한 나열 시 공백이 없어야 한다.

2) chmod go=r sysbin 또는 chmod g=r,o=r sysbin
3) chmod 754 sysbin

0200. ○ △ × 14.2회.산기 22.1회.산기

공격자가 실행파일에 SUID(setuid)를 설정하려고 한다. (A)는 권한 변경을 위한 명령어, (B)는 변경에 따른 접근권한을 나타낸다. 빈칸에 적절한 용어를 기술하시오.(단, 파일에 대해 SUID만 설정하고 다른 접근권한은 변경하지 않음)

보기

```
# ls -l backdoor
-rwxr-xr-x  1  root  root  179492  7월25일  04:00  backdoor
# (  A  ) ./backdoor
# ls -l backdoor
(  B  )  1  root  root  179492  7월25일  04:15  backdoor
```

정답 및 해설

(A) chmod u+s 또는 chmod 4755
(B) -rwsr-xr-x

0201. ○△× 17.2회.산기

다음 보기를 참조하여 각 질문에 답하시오.

보기

```
#ls -l rootkit
-rwxrwxr-x 1 root root 148678 12월25일 01:15 rootkit
#( A ) ./rootkit
#ls -l rootkit
( B ) 1 root root 148678 12월25일 01:16 rootkit
```

1) 공격자가 접근권한 변경을 위해 rootkit 실행파일에 대해 SUID(setuid) 비트를 설정하려고 한다. A에 들어갈 명령어를 쓰시오.
2) (1)의 명령 이후에 rootkit 실행파일의 접근권한 정보를 B에 쓰시오.
3) 공격자가 SUID 비트를 설정하면 어떤 문제가 발생하는지 쓰시오.

정답 및 해설

1) A : chmod u+s 또는 chmod 4775
2) B : -rwsrwxr-x
3) SUID 비트가 설정되면 rootkit이 실행 중인 동안에 rootkit 실행파일 소유자, 즉 root의 권한으로 중요 자원에 접근하여 악의적인 행위를 수행할 수 있는 문제점이 있다.

0202. ○△× 17.1회.산기

다음 보기의 내용과 관련된 질문에 답하시오.

보기

유닉스/리눅스 시스템의 ps 명령은 현재 실행 중인 프로세스 상태정보를 보여주는 명령어로 다음과 같이 동작하는 것으로 가정한다.

가) ps 명령은 먼저 시스템 프로세스 테이블에 있는 현재 프로세스 정보를 /tmp 디렉터리에 ps.xx 라는 이름으로 복사한다.
(xx는 ps 명령을 수행한 프로세스의 id를 의미한다)

나) ps.xx 파일 내용을 사용자에게 출력하는 작업은 시간이 다소 소요되며 이를 위해 임시로 ps.xx 소유자를 root로 변경한 다음 파일명을 ps.dat로 변경한다.

유닉스/리눅스 시스템의 ps 동작 방식을 파악한 공격자는 다음과 같은 공격을 수행한다.
(단, /tmp 디렉터리는 sticky bit가 설정되어 있지 않고 777의 접근권한을 가지고 있는 것으로 가정한다)

① 공격자는 접근할 수 있는 디렉터리에 sh 실행파일(shell 파일)을 'system-sh'라는 이름으로 복사한다.
② 'system-sh' 파일의 접근권한을 4755로 설정한다.
③ ps 명령을 실행한다.
④ ps.xx 파일이 생성되고 소유자가 root로 바뀌기 전에 아래 명령을 빠르게 수행한다.
- rm -rf /tmp/ps.xx
- ln -s system-sh /tmp/ps.xx

1) /tmp에서 sticky bit 권한의 의미를 서술하시오.
2) /tmp에서 sticky bit 권한을 설정하면 어떻게 공격을 방지할 수 있는지 서술하시오.
3) 공격 절차 ②에서 system-sh에 부여한 4755 접근권한의 의미를 서술하시오.
4) 공격이 성공했을 때 발생할 수 있는 문제점을 서술하시오.

정답 및 해설

1) sticky bit가 설정된 디렉터리는 모든 사용자가 자유롭게 파일을 생성할 수 있지만 소유자 또는 root만이 파일 삭제 및 파일명 변경이 가능하다.
2) 공격자가 악의적인 심볼릭 링크 파일 생성을 위해 /tmp/ps.xx 파일 삭제 시도 시 sticky bit 권한이 설정되어 있으면 본인 소유의 파일이 아니므로 삭제에 실패하여 공격을 방어할 수 있다.
3) 공격자는 system-sh 셸이 소유자의 권한으로 실행되게 하려고 SUID(4755) 권한을 부여하고 있다.
4) 공격에 성공하게 되면 공격자는 root 권한의 셸(system-sh)을 획득하여 시스템 중요 자원에 root 권한으로 접근할 수 있는 문제점이 있다.

0203. ○ △ × 25.4회.기사

다음은 리눅스 시스템 관련 보안 설정에 관한 내용이다. 각각의 질문에 답하시오.

1) 세션 타임아웃(Session Timeout)을 600초(10분)로 설정하시오.

2) root 계정의 원격 접속을 차단하기 위해 pts/0 ~ pts/x 항목을 제거해야 하는 설정 파일명을 절대경로로 쓰시오.

3) /etc/passwd 파일과 /etc/shadow 파일에 적용해야 할 권장 접근권한(Permission)을 각각 쓰시오.
   ① chmod ( ) /etc/passwd
   ② chmod ( ) /etc/shadow

4) world writable 속성을 가진 파일을 모두 검출하기 위한 find 명령을 작성하시오.

5) 새로 생성되는 파일이 rw-r--r--(644) 접근권한을 갖도록 설정하는 명령을 쓰시오.

6) xinetd 서비스 설정 파일에서 서비스를 비활성화하는 빈칸( )의 옵션을 쓰시오.

```
service telnet
{
  (      )  = no
  flags      = REUSE
  socket_type = stream
  wait       = no
  user       = root
  server     = /usr/sbin/in.telnetd
  ~~(이하 생략)~~
}
```

정답 및 해설

1) 사용자 환경설정 파일(예: /etc/profile 등)에 export TMOUT=600 또는 TMOUT=600; export TMOUT을 설정

2) /etc/securetty
   - pam_securetty.so PAM 모듈이 참조하는 설정 파일로 pts 항목이 없거나 주석 처리되어 있으면 root 원격 접속이 차단된다.

3) ① 644, ② 400
   - /etc/passwd 파일은 644, /etc/shadow 파일은 400 이하 접근권한 설정을 권장한다.

4) find / -type f -perm -2
   - world writable 파일 : 모든 사용자(others)가 쓰기(write) 권한을 가지고 있어 누구나 내용을 변경할 수 있는 파일

5) umask 022

6) disable

0204. ○ △ × 15.1회.산기

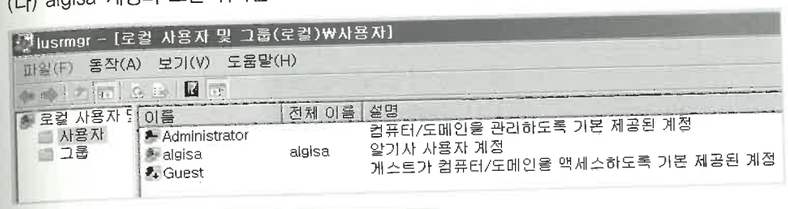
다음은 한 Windows Server 시스템의 사용자 계정에 관한 정보를 보여주는 그림들이다. 그림이 보여주는 내용을 분석하여 사용자 계정 관리의 보안 취약점들을 지적하시오.

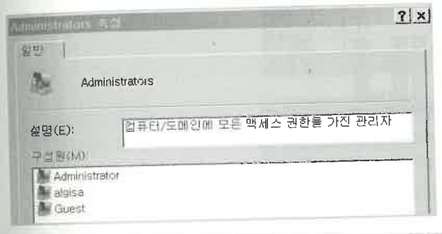
(그림에서 Administrator는 시스템 관리자 계정, Guest는 게스트(guest) 계정, algisa는 일반 사용자 계정이다. 또한 시스템의 C: 디스크는 부트(boot) 디스크이다.)

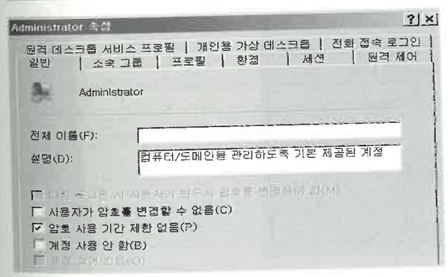
(가) Administrator 계정의 보안 취약점

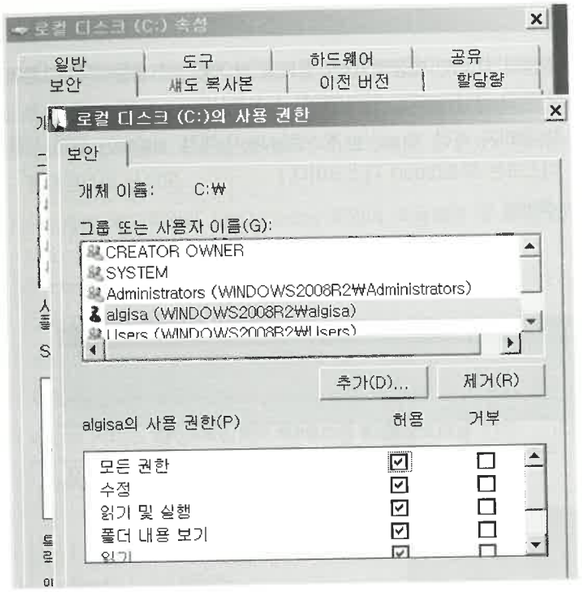
(나) Guest 계정의 보안 취약점

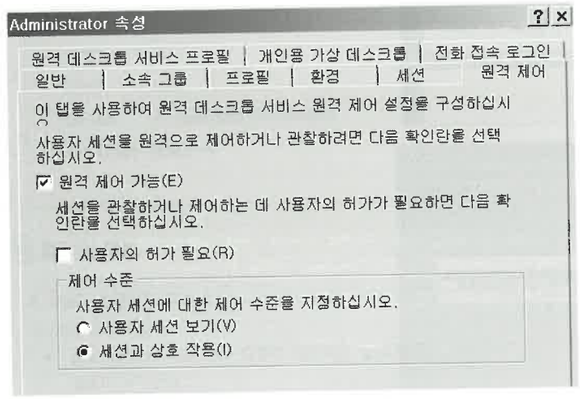
(다) algisa 계정의 보안 취약점











정답 및 해설

(가) Administrator 계정의 보안 취약점

- Administrator 계정명을 쉽게 유추할 수 없는 이름으로 변경한다.
- 관리자 계정(Administrator)의 최대 암호 사용기간이 설정되어 있지 않아 공격자의 무차별 공격으로부터 취약하다. '암호 사용 기간 제한 없음' 체크를 해제한다.
- 원격 제어는 접속한 사용자의 세션을 모니터링하거나 제어할 수 있는 설정이다. Administrator 세션에 대하여 외부에서 원격 제어를 하지 못하도록 '원격 제어 가능'을 해제하거나, 원격 제어 구성 시 '사용자의 허가 필요' 항목을 체크하여 Administrator 세션에 대하여 악의적인 원격 제어를 차단한다.

(나) Guest 계정의 보안 취약점

- Administrators 그룹에서 불필요한 Guest 계정을 제거한다.

(다) algisa 계정의 보안 취약점

- Administrators 그룹에서 불필요한 일반 사용자 계정인 algisa 계정을 제거한다.
- C:(파일시스템)에 일반 사용자(algisa)가 모든 권한을 가지고 있으면 권한 및 소유자 변경 등의 작업이 가능하므로 관리자 외에는 모든 권한을 제거한다.

SECTION 2

네트워크 보안

01 네트워크 보안 단답형
02 네트워크 보안 서술형
03 네트워크 보안 실무형

SECTION 02

네트워크 보안

보안멘토

네트워크 보안은 시스템 보안과 함께 출제 비중이 가장 높은 영역입니다. 특히 네트워크 기반의 다양한 공격 기법과 관련된 문제들은 단순한 개념 암기보다는, 문제에 제시된 패킷 로그나 상황 정보를 분석하여 공격 원리와 판단 근거, 그리고 적절한 대응 방안을 서술할 수 있도록 준비하셔야 합니다. 또한 IPsec, SSL/TLS와 같은 주요 보안 프로토콜에 대해서는 동작 원리와 구성 요소를 중심으로 충분히 이해하고 정리해 두시는 것이 필요합니다.

01. 네트워크 보안 단답형

0205. ○ △ × 21.1회.산기

다음 보기는 통신 프로토콜의 특성을 이용하는 네트워크 공격에 대한 설명이다. 각각의 공격 명칭을 쓰시오.

보기

(A) : 네트워크 대역을 고갈시키는 등의 공격을 말한다. 대표적으로 TCP SYN Flooding, HTTP GET Flooding, HTTP CC 등의 공격 기법이 있다. 해당 공격이 발생하면 공격 대상 사이트의 서비스 가용성에 심각한 영향을 미친다.

(B) : 공격 도구를 이용하여 랜카드를 무차별 모드(Promiscuous Mode)로 설정한 후 연결된 회선에 흐르는 모든 IP 패킷을 가로채는 공격을 말한다. 대표적으로 스위치 재밍(switch jamming), SPAN 포트 태핑 등의 공격 기법이 있다.

(C) : 포트(Port) 번호, IP 주소, MAC 주소 등을 조작하여 네트워크 트래픽 흐름을 왜곡하고 시스템 권한 탈취 등의 행위를 수행하는 공격을 말한다. 대표적으로 ARP (C) 공격, IP (C) 공격, DNS (C) 공격 등이 있다.

정답 및 해설

주요 네트워크 보안 공격을 정리해 보면 다음과 같다.

1) 스니핑(Sniffing) 공격 : 사전적 의미는 '코를 킁킁거리다', '냄새를 맡다'
- 네트워크 트래픽을 몰래 엿듣는(훔쳐보는) 공격 행위를 말한다. 스니핑을 위한 대표적인 공격 기법에는 '스위치 재밍(MAC Flooding)', 'ARP Spoofing/Redirect', 'ICMP Redirect', 'SPAN/포트 미러링 기능 이용', '미러링 장비(예: TAP 장비) 이용' 등이 있다.

2) 스누핑(Snooping) 공격 : 사전적 의미는 '기웃거리다', '염탐하다'
- 네트워크 트래픽상의 정보를 몰래 획득하는 공격 행위를 말한다. 스니핑과 의미상 유사하지만, 스니핑은 몰래 엿듣는다는 의미가 강하고 스누핑은 몰래 정보를 획득한다는 의미가 강하다.

3) 스푸핑(Spoofing) 공격 : 사전적 의미는 '속이다'
- TCP/IP 프로토콜의 구조적 결함을 이용한 공격 기법으로 공격 도구를 이용하여 MAC 주소, IP 주소, Port 번호, 도메인 정보 등을 조작하여 네트워크 트래픽 흐름을 왜곡하거나 시스템 권한 탈취 등의 악의적인 행위를 수행하는 공격을 말한다. 대표적인 공격 기법에는 'ARP Spoofing', 'IP Spoofing', 'DNS Spoofing' 등이 있다.

4) 도스/디도스(DoS/DDoS) 공격 : Denial of Service(서비스 거부) / Distributed DoS(분산 서비스 거부)
- 비정상적인(악의적인) 트래픽을 발생시켜서 희생자의 네트워크 대역폭을 소진시키거나 시스템 자원을 소진시키거나 웹/DB 서버의 부하를 유발하여 정상적인 서비스를 할 수 없도록 만드는 형태의 공격을 말한다.

정답 (A) 도스(DoS) 또는 디도스(DDoS) (B) 스니핑(Sniffing) (C) 스푸핑(Spoofing)

0206. ○ △ × 24.2회.산기

다음 빈칸( )에 들어갈 용어를 보기에서 고르시오.

보기

기밀성, 무결성, 가용성, 부인방지, 인증

비정상적인 트래픽을 대량으로 발생시켜 네트워크 자원, 시스템 자원 등을 소모하게 하는 TCP SYN Flooding 공격, 분산 서비스 거부 공격(DDoS) 등은 보안 요소 중에 ( )을/를 침해하는 공격이다.

정답 및 해설

가용성(Availability)은 권한 있는 자(인가된 주체, 정당한 자)의 정보자산 접근 필요시 언제든지(즉시, 지체없이) 접근할 수 있도록 보장하는 것을 말한다. 즉, 재해/장애 시에도 정상적인 서비스가 가능하도록 보장하는 것을 의미하며 가용성을 훼손하는 대표적인 공격에는 도스/디도스 공격이 있다.

정답 가용성

0207. ○ △ ×

다음과 같은 특징을 가진 주소는 OSI 7계층 중 어디에 해당하는가?

보기
- 6바이트(48비트)로 구성
- 상위 3바이트는 제조사 식별 코드, 하위 3바이트는 제조사가 할당한 코드(일련번호)
- (표기 예) 00:20:AF:21:3C:80

정답 및 해설

- 6바이트(48비트)로 구성되며, 상위 3바이트는 제조사(벤더) 코드, 하위 3바이트는 제조사(벤더)에서 할당한 코드라는 것은 MAC 주소에 대한 설명이며, MAC 주소는 OSI의 2계층인 데이터링크 계층에서 동작한다.
- 데이터링크 계층은 인접한 노드 간의 신뢰성 있는 프레임(Frame) 전송을 담당하는 계층으로 목적지 노드를 식별하기 위해서는 물리적인 주소가 필요하며 네트워크 인터페이스 카드(NIC)의 MAC 주소가 해당 역할을 한다.

정답 데이터링크 계층

0208. ○△×

다음 각각의 질문에 답하시오.

1) 데이터링크 계층의 공유 매체 접근 제어 기술 중 이더넷(IEEE 802.3) 표준에서 사용하는 기술은 무엇인가?

2) 데이터링크 계층의 공유 매체 접근 제어 기술 중 무선랜(IEEE 802.11) 표준에서 사용하는 기술은 무엇인가?

정답 및 해설

1) CSMA/CD(Carrier Sense Multiple Access/Collision Detection) : 충돌 탐지 방식
   - 이더넷(IEEE 802.3) 표준에서 사용하는 공유 매체 접근 제어 방식
   - 공유 매체가 사용 중인지를 감지한 후 매체가 비어있으면 프레임을 전송하고 전송 완료 이전에 신호 충돌을 탐지하여 충돌이 발생하면 임의의 시간 동안 대기후에 재전송을 수행하는 접근 제어 방식
2) CSMA/CA(Carrier Sense Multiple Access/Collision Avoidance) : 충돌 회피 방식
   - 무선랜(IEEE 802.11) 표준에서 사용하는 공유 매체 접근 제어 방식
   - 무선랜 환경에서는 공유 매체(공기 매체)의 특성상 다른 장치의 신호를 감지하고 충돌을 탐지하기 어렵기 때문에, 사전에 충돌을 가능한 회피하는 방식을 사용한다.
   - 전송 전에 공유 매체 사용 여부를 확인하고 일정 시간 대기후에 전송 및 수신 여부를 확인하여(수신 확인 메시지) 실패 시 재전송을 수행하는 접근 제어 방식

정답 (1) CSMA/CD (2) CSMA/CA

0209. ○△×

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

(A) 제어방식은 유선랜(이더넷) 환경에서 데이터를 송신하려는 컴퓨터가 네트워크상에 다른 컴퓨터가 통신하고 있는지를 조사해 신호가 송출되고 있지 않을 시 데이터를 전송하는 방식으로 동시에 여러 컴퓨터에서 데이터를 전송하면 충돌이 발생한다. 충돌이 발생하면 이를 감지하여 전송을 중단한 후 일정 시간 경과 후에 다시 신호를 보낸다.
(B)은/는 공유하는 전송 매체에 연결된 장치들이 동시에 매체에 접근하려고 하는 경우 신호가 충돌하는 영역을 말한다.
(C)은/는 브로드캐스트 신호를 수신할 수 있는 영역을 말한다.

정답 및 해설

1) 충돌 도메인(Collision Domain) : 전송 매체를 공유하는 LAN 환경에서 하나의 장치가 신호를 보내고 있을 때 또 다른 장치가 신호를 동시에 보내면 신호 충돌이 발생한다. 이처럼 충돌이 발생할 수 있는 영역을 충돌 도메인이라 한다.
2) 브로드캐스트 도메인(Broadcast Domain) : 브로드캐스트 신호가 발생했을 때 전달되는 영역을 말한다.

정답 (A) CSMA/CD (B) 충돌 도메인(Collision Domain) (C) 브로드캐스트 도메인(Broadcast Domain)

0210. ○△× 24.2회.기사

무선랜 CSMA/CA 통신에서는 모든 통신에 대해 연결 타임아웃(연결 지속시간)이 적용된다. 이때 연결 타임아웃 설정이 어느 신호(프레임)에 포함되는지 보기에서 2개 고르시오.

보기

CTS, DATA, RTS, SYN, ACK, RST

정답 및 해설

무선랜 CSMA/CA 통신에서는 충돌 회피(Collision Avoidance)를 위해 RTS(Request To Send)/CTS(Clear To Send) 방식을 이용한다. 송신을 원하는 노드가 RTS 신호를 수신 노드에 보내면 수신 노드는 통신이 가능한 경우에만 CTS 신호를 요청한 노드를 포함하여 모든 노드에 보내 특정 노드와 통신한다는 사실을 알리게 된다. 이때 RTS/CTS 신호에는 프레임 전송에 얼마나 시간이 걸리는지를 나타내는 정보(NAV : Network Allocate Vector, 연결 지속시간)가 포함되어 있어 해당 시간 동안 다른 노드의 접근을 막아줄 수 있다.

정답 RTS, CTS

0211. ○ △ × 22.2회.산기

다음 보기의 빈칸( )에 적절한 스위치(Switch) 장비의 전송 방식(LAN 스위칭 방식)을 쓰시오.

보기

(A) : 수신된 프레임 전체를 내부 버퍼에 저장하고 CRC 등의 오류 검사를 수행한 후 목적지로 전송하는 방식
(B) : 수신된 프레임의 첫 6byte를 읽어 Destination MAC 주소(목적지 MAC 주소)를 검사한 후 즉시 목적지로 전송하는 방식
(C) : 위 2가지 방식을 결합한 방식으로 수신된 프레임의 첫 64byte를 저장하고 충돌(collision) 등의 오류 검사를 수행한 후 목적지로 전송하는 방식

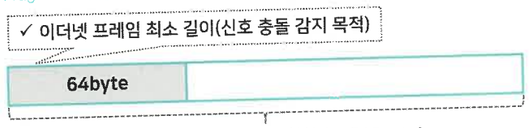
정답 및 해설

스위치(Switch)의 프레임 전달 방식(LAN 스위칭 방식)을 살펴보면 다음과 같다.

1) Store-and-Forward 방식

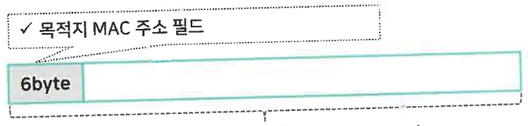
- 유입된 전체 프레임을 버퍼에 저장하고 프레임 오류 검사(CRC 검사)를 수행한 후 신호 충돌(Collision) 여부를 감지하면서 목적지로 전송하는 방식
- 전체 프레임에 대한 오류 및 신호 충돌 검사를 수행하기 때문에 신뢰성이 높은 장점이 있지만 저장과 검사를 위한 지연 시간이 발생한다는 단점이 있다.

2) Fragment-Free 방식



- 유입된 프레임의 첫 64byte를 확인한 후 충돌(Collision) 여부를 감지하면서 목적지로 전송하는 방식
- 이더넷(Ethernet)의 경우 신호 충돌을 감지하기 위해서는 최소 64byte 크기의 프레임이 필요하다.

3) Cut-Through 방식



- 유입된 프레임의 첫 6byte를 읽어 목적지 MAC 주소를 확인한 후 즉시 전송하는 방식
- 지연 시간이 줄어 빠른 전송이 가능하다는 장점이 있지만 프레임 오류 및 신호 충돌 검사를 하지 않기 때문에 신뢰성이 낮은 단점이 있다.

정답 (A) Store-and-Forward 방식 (B) Cut-Through 방식 (C) Fragment-Free 방식

0212. ○ △ × 22.1회.산기

다음 보기에서 설명하는 스위치(Switch) 장비의 전송 방식(LAN 스위칭 방식)을 쓰시오.

보기

네트워크 장비인 스위치(Switch)의 중계 지연 시간(Forwarding Time Latency)을 최소화하기 위해 사용되는 전송 방식으로 전체 프레임이 수신되기를 기다리는 것 대신에 수신되는 프레임의 목적지 주소(MAC 주소)만 확인하고 바로 해당 목적지 포트로 수신한 데이터를 전송한다. 전송속도가 빠르다는 장점이 있지만 목적지 주소만 확인하고 전송하기 때문에 오류가 발생한 프레임까지도 전송하는 경우가 발생하는 단점이 있다.

정답 및 해설

정답 Cut-Through 방식

0213. ○ △ × 23.4회.기사 25.4회.기사

스위치(Switch) 장비의 LAN 스위칭(Switching) 방식(기법) 3가지를 쓰시오.

정답 및 해설

LAN 스위칭(Switching)은 스위치에 입력된 이더넷 프레임을 어떤 방식으로 출력 포트에 전달할지를 결정하는 전송 방식을 의미한다. 대표적인 스위칭 방식으로는 Store-and-Forward 방식, Fragment-Free 방식, Cut-Through 방식이 있다.

정답 Store-and-Forward 방식, Fragment-Free 방식, Cut-Through 방식

0214. ○ △ ×

스위치 환경에서 모니터링과 트래픽 분석을 위해 특정 포트로 전달되는 패킷 또는 VLAN의 모든 패킷을 다른 모니터링 포트로 복제하여 전달하는 기능을 무엇이라 하는가?

정답 및 해설

스위치는 허브처럼 특정 포트에서 유입된 패킷을 모든 포트로 전달하지 않기 때문에 스위치로 전달되는 패킷을 분석하려면 스위치에서 제공하는 포트 미러링(Port Mirroring) 기능을 사용해야 한다. 시스코 스위치 장비에서는 SPAN(Switch Port ANalyzer) 기능이라고도 한다.

정답 포트 미러링(Port Mirroring) 또는 SPAN

0215. ○△× 13.1회.산기

데이터링크 계층의 브로드캐스트와 멀티캐스트를 포워딩하지 않으며, 서로 다른 VLAN 간에 통신을 가능하게 하고, 기본적인 보안 기능과 QoS 관련 기능을 지원할 수 있는 OSI 계층 중 네트워크 계층에서 작동하는 네트워크 장비는 무엇인가?

정답 및 해설

라우터(router)는 서로 다른 네트워크(서로 다른 LAN(VLAN))를 연결하여 라우팅(최적의 경로 선정)을 통해 IP 패킷을 목적지로 전달해 주는(포워딩) 네트워크 계층 장비로 핵심적인 라우팅 및 포워딩 기능 외에도 다음과 같은 부가 기능을 제공한다.

- 데이터링크 계층의 브로드캐스트 및 멀티캐스트 프레임이 다른 네트워크(다른 LAN(VLAN))로 전달되지 않도록 차단
- 패킷 필터링 기능(ACL 기능) : IP 패킷에 대한 접근통제 기능
- QoS(Quality of Service, 서비스 품질) 기능 : 서비스별로 전송 우선순위(전송속도, 네트워크 대역폭)를 조절하는 기능

정답 라우터(router)

0216. ○△×

다음 설명은 OSI 7계층 중 어느 계층에 대한 설명인가?

보기

- 통신장치에서의 서로 다른 데이터 표현 방식, 부호 체계 간의 변환에 관한 규정
- 데이터의 압축과 압축해제, 암호화와 복호화, 인코딩 및 디코딩 등을 담당

정답 및 해설

표현 계층(Presentation Layer)은 송수신 데이터 표현 방식의 변환을 담당하는 계층이다. 주요 기능은 다음과 같다.

- 암호화/복호화 : 암호화와 복호화를 통하여 데이터 보안성을 제공한다.
- 압축/압축해제 : 송신 측에서는 데이터의 압축을 통하여 전송률을 높이고 수신 측에서는 압축해제를 통하여 데이터를 이용한다.
- 인코딩/디코딩 : 서로 다른 형태의 코드 변환을 수행한다.

정답 표현 계층(Presentation Layer)

0217. ○△× 15.2회.산기 23.2회.산기

다음 보기의 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

OSI 7 Layer 모델에서 인코딩(ASCII, EBCDIC), 압축, 암 · 복호화 등을 담당하는 계층은 (A) 계층이다. 이 계층은 TCP/IP 4계층 구조에서 (B) 계층에 속한다.

정답 및 해설

정답 (A) 표현(Presentation) (B) 응용(Application)

0218. ○△×

다음은 OSI 7 Layer의 각 계층에 대한 설명이다. 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

(A) 계층은 전송 데이터 단위로 프레임(frame)을 사용하고, 대표적인 장비로 스위치(switch), 브릿지(bridge) 등이 있으며 대표적인 보안 프로토콜로 PPTP, L2F, L2TP 등이 있다.
(B) 계층은 전송 데이터 단위로 패킷(packet)을 사용하고, 경로 결정에 사용할 논리적 주소를 제공하며 대표적인 장비로는 라우터(router)가 있고 대표적인 보안 프로토콜로 IPsec이 있다.
(C) 계층은 전송 데이터 단위로 세그먼트(segment)를 사용하고, 대표적인 보안 프로토콜로 SSL/TLS가 있다.

정답 및 해설

정답 (A) 데이터링크(Data Link) (B) 네트워크(Network) (C) 전송(Transport)

0219. ○△× 17.1회.산기

다음 보기의 빈칸( )에 알맞은 용어를 쓰시오.

보기

네트워크 패킷 분석 시 PDU(Protocol Data Unit)는 데이터를 전송하기 위한 전송단위로 계층별 부가 정보의 추가 상태를 의미한다. 일반적으로 계층별로 LxPDU와 같이 표현하는데 L4PDU를 (A), L3PDU를 (B), L2PDU를 (C), L1PDU를 비트(bit)라고 한다.

정답 및 해설

PDU(Protocol Data Unit)는 OSI 7 Layer 계층별 프로토콜의 데이터 단위를 의미한다. PDU를 정리해 보면 다음과 같다.

- Physical Layer(L1 : 물리 계층) : 비트(bit)
- Data Link Layer(L2 : 데이터링크 계층) : 프레임(Frame)
- Network Layer(L3 : 네트워크 계층) : 패킷(Packet)
- Transport Layer(L4 : 전송 계층) : 세그먼트(Segment)
- Session/Presentation/Application Layer(L5/L6/L7 : 세션/표현/응용 계층) : 데이터(Data)

정답 (A) 세그먼트(Segment) (B) 패킷(Packet) (C) 프레임(Frame)

0220. ○ △ × 17.2회.산기

다음은 OSI 7 Layer에서 사용하는 프로토콜 데이터 단위(PDU:Protocol Data Unit)를 설명한 내용이다. 계층별 빈칸에 적절한 용어를 쓰시오.

보기
- 1계층(물리 계층) : (A)
- 2계층(데이터링크 계층) : (B)
- 3계층(네트워크 계층) : (C)
- 4계층(전송 계층) : (D)
- 5-6-7계층(세션-표현-응용 계층) : 데이터(Data)

정답 및 해설

정답 (A) 비트(Bit) (B) 프레임(Frame) (C) 패킷(Packet) (D) 세그먼트(Segment)

0221. ○ △ × 16.2회.산기

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

IP 패킷이 목적지 노드에 전달되기 위해서는 IP 주소에 대응되는 (A) bits의 MAC 주소를 알아야 한다. 이때 (B) 프로토콜은 IP 주소를 MAC 주소로 변환하기 위해 MAC 계층 브로드캐스트를 사용한다.

정답 및 해설

정답 (A) 48 (B) ARP(Address Resolution Protocol)

0222. ○ △ × 17.1회.산기

다음 빈칸 (A), (B)에 알맞은 용어를 쓰시오.

보기

ARP(Address Resolution Protocol) 프로토콜은 (A)에 대응하는 (B)을/를 알려주는 기능을 수행하고 RARP(Reverse ARP) 프로토콜은 (B)에 대응하는 (A)을/를 알려주는 기능을 수행한다.

정답 및 해설

정답 (A) IP 주소 (B) MAC 주소

0223. ○ △ × 24.4회.기사 25.4회.산기

다음 설명하는 프로토콜을 보기에서 고르시오.

보기

ICMP, IGMP, ARP, RARP, RIP, OSPF, HTTP, SNMP

- 물리적인 MAC 주소를 논리적인 IP 주소로 변환해 주는 프로토콜로 요청 및 응답 메시지로 동작한다.
- 하드디스크가 없는 호스트가 부팅 시 자신의 MAC 주소를 기반으로 IP 주소를 서버로부터 얻어내기 위해 사용하는 TCP/IP 기반 프로토콜

정답 및 해설

RARP(Reverse ARP) 프로토콜의 기능 및 주요 특징은 다음과 같다.
- 물리적인 MAC 주소를 논리적인 IP 주소로 변환해 주는 역할을 하는 프로토콜
- 일반적으로 IP 주소는 시스템의 하드디스크 내 설정 파일에 저장되어 있지만 하드디스크가 없는 터미널의 경우 초기 가동될 때 자신의 MAC 주소를 담아 RARP 요청을 보내고 RARP 서버로부터 자신의 IP 주소를 제공받는다.
- MAC 주소에 대한 IP 주소 정보를 관리하는 RARP 서버가 구성되어 있어야 한다.

정답 RARP

0224. ○ △ × 19.2회.기사 23.1회.기사

ARP(Address Resolution Protocol) 프로토콜은 논리적인 IP 주소를 물리적인 MAC 주소로 변환해 주는 프로토콜로 ARP 요청 메시지와 ARP 응답 메시지로 동작한다. 물리적인 주소(MAC 주소)를 얻기 위한 요청 메시지를 보낼 때 요청 이더넷 프레임(Ethernet Frame)의 목적지 주소가 어떻게 설정되는지 해당 주소 표기법으로 작성하시오.

정답 및 해설

ARP 프로토콜은 로컬 네트워크의 모든 호스트에게 대상 IP를 가진 호스트의 MAC 주소를 질의하는 요청 메시지를 만들어 브로드캐스트(broadcast) 방식으로 요청하고 대상 IP가 설정된 호스트는 자신의 MAC 주소를 담은 응답 메시지를 만들어 요청한 호스트에게 유니캐스트(unicast) 방식으로 응답한다.
따라서 요청 메시지를 전송할 때는 프레임의 목적지 MAC 주소 필드에 브로드캐스트 주소인 FF:FF:FF:FF:FF:FF (48bit 모두 1로 설정된 주소로 :(콜론)을 구분자로 한 헥사값으로 표현)가 설정된다.

정답 FF:FF:FF:FF:FF:FF

0225. ○ △ × 24.4회.산기

다음 빈칸(　)에 들어갈 용어를 보기에서 고르시오.

보기

TCP Dump, ARP Spoofing, Promiscuous, ARP Redirect, Fragrouter

일반적으로 네트워크 인터페이스 카드(NIC)의 동작 모드는 자신을 목적지로 하는 트래픽만 수신한다. 하지만 네트워크 스니핑을 하거나 모니터링 목적으로 다른 시스템에 전달되는 트래픽도 수신하는 경우가 있다. 이때 설정하는 네트워크 인터페이스 카드(NIC)의 동작 모드는 (　)이다.

정답 및 해설

네트워크 인터페이스 카드(NIC : Network Interface Card)의 Promiscuous Mode(무차별 모드)는 유입된 프레임(패킷)의 목적지 MAC 주소와 무관하게 모든 프레임(패킷)을 수신하는 동작 모드를 말한다. 네트워크 인터페이스 카드가 Promiscuous Mode로 설정되면 자신이 목적지가 아닌 프레임(패킷)도 모두 수신하므로 네트워크 스니핑(sniffing) 공격이 발생할 수 있다.

답 Promiscuous

0226. ○ △ × 14.1회.산기

다음 보기에서 설명하고 있는 공격 기법을 쓰시오.

보기

MAC 주소를 속이는 공격으로 로컬에서 통신하고 있는 서버와 클라이언트의 IP 주소에 대한 2계층 MAC 주소를 공격자의 MAC 주소로 속임으로써 클라이언트에서 서버로 가는 패킷(또는 서버에서 클라이언트로 가는 패킷)의 흐름을 왜곡시킨다.

정답 및 해설

답 ARP 스푸핑(Spoofing)

0227. ○ △ × 19.1회.기사 22.1회.기사

다음 보기에서 설명하고 있는 공격 기법을 쓰시오.

보기

공격자가 다른 호스트의 MAC 주소를 자신의 MAC 주소로 위조한 응답 메시지를 만들어 지속해서 희생자에게 전송하면 희생자의 캐시(Cache) 정보가 조작되어 희생자가 조작된 호스트로 패킷을 전송할 때 캐시에 저장된 조작된 MAC 주소인 공격자에게 전송된다.

정답 및 해설

답 ARP 스푸핑(Spoofing)

0228. ○ △ × 13.2회.기사

다음은 스위칭 환경에서 스니핑 공격과정을 설명하고 있다. 이에 해당하는 공격 기법을 쓰시오.

보기

일반적으로 스위치 장비들은 MAC 주소 테이블이 가득 차게 되면 모든 네트워크 세그먼트 트래픽을 브로드캐스트하는 특징을 가지고 있다. 따라서 공격자는 위조된 MAC 주소를 지속해서 네트워크에 흘림으로써 스위칭 허브의 주소 테이블을 오버플로우시켜 허브처럼 동작하게 하여 해당 네트워크 세그먼트의 데이터를 스니핑할 수 있게 된다. 이는 일반적인 스위치 장비가 보안 원리의 하나인 "Fail Close"를 따르지 않기 때문이다.
결국 공격자가 만들어 낸 임의의 ARP 패킷의 MAC 주소가 스위치의 주소 테이블을 오버플로우 시키게 되는 것이 공격 성공의 주요 요인이다.

정답 및 해설

답 스위치 재밍(Switch Jamming) 또는 MAC 플러딩(Flooding) 공격

0229. ○ △ × 23.1회.산기

회사 내 네트워크의 호스트 IP 주소가 133.253.27.45라고 할 때 다음 각각의 질문에 답하시오. (클래스 기반 IP 주소 할당 방식 사용)

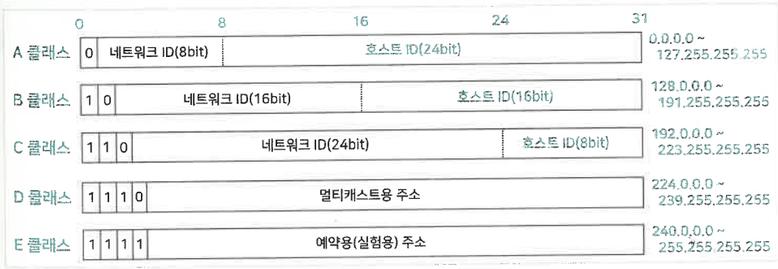
1) 회사 내 네트워크에서 사용할 수 있는 호스트 주소의 개수(address space)를 쓰시오.

2) 회사 내 네트워크의 네트워크 주소를 쓰시오.

3) 회사 내 네트워크의 브로드캐스트(broadcast) 주소를 쓰시오.

정답 및 해설

클래스(class) 기반 IP 주소 할당 기법(classful IP addressing)



1) $2^{16} - 2$

- 133.253.27.45는 B 클래스(128.0.0.0~191.255.255.255)에 속하는 IP 주소이므로 상위 2바이트는 네트워크 ID로 사용되고 하위 2바이트는 호스트 ID로 사용된다.
- 하위 2바이트 중 예약된 네트워크 주소(호스트 ID 비트가 모두 0)와 브로드캐스트 주소(호스트 ID 비트가 모두 1)를 제외하고 호스트 주소로 사용할 수 있다.

2) 133.253.0.0

- 네트워크 주소는 해당 네트워크 자체를 식별하기 위한 주소로 IP 주소의 호스트 ID 비트가 모두 0인 주소로 예약되어 있다.

3) 133.253.255.255

- 브로드캐스트 주소는 해당 네트워크 내 모든 호스트로 패킷을 전송할 때 사용하는 주소로 IP 주소의 호스트 ID 비트가 모두 1인 주소로 예약되어 있다.

0230. ○ △ × 24.1회.기사

IP 주소가 200.100.50.25(C 클래스)이고 서브넷 마스크(subnet mask)가 255.255.255.192일 때 서브넷 마스크를 2진수로 작성하시오.

정답 및 해설

	11001000(200)	01100100(100)	00110010(50)	00011001(25)	(IP 주소)
&	11111111(255)	11111111(255)	11111111(255)	11000000(192)	(서브넷 마스크)
	11001000(200)	01100100(100)	00110010(50)	00000000(0)	(네트워크 주소)

- 대상 네트워크의 IP 주소 범위 : 200.100.50.00000000(0) ~ 200.100.50.00111111(63)
- 대상 네트워크에서 호스트에 할당할 수 있는 IP 주소 개수 : 2^6 -2 = 62(네트워크 주소 및 브로드캐스트 주소 제외)
- 대상 네트워크의 네트워크 주소 : 200.100.50.00000000(0)
- 대상 네트워크의 브로드캐스트 주소 : 200.100.50.00111111(63)

정답 11111111.11111111.11111111.11000000

0231. ○ △ ×

IPv4에서 무한 루핑을 방지하기 위해 라우터를 거칠 때마다 감소시키는 IP 헤더 필드명은 무엇인가?

정답 및 해설

- TTL(Time to Live)은 목적지로 가기 위해 IP 패킷이 경유할 수 있는 라우터의 개수(홉 카운트)를 의미한다. TTL의 목적은 라우팅 테이블 오류 등으로 무한 루핑이 발생한 IP 패킷이 무한히 생존하여 네트워크 대역을 소모하는 상황을 방지하기 위함이다.
- 라우터를 거치면서 TTL은 1씩 감소하며 목적지 도착 전에 TTL값이 0이 되면 해당 패킷을 폐기한 후 ICMP 에러 메시지를 최초 출발지로 전송한다.

정답 TTL(Time To Live)

0232. ○ △ × 17.1회.기사

IP 단편화(Fragmentation)는 다양한 네트워크 환경에서 IP 패킷의 효율적인 전송을 가능하게 하는 패킷 분할 기법이다. IP 데이터그램을 단편화할 때 tcpdump의 내용 중 다음 A, B, C가 의미하는 바를 쓰시오.

보기

04:05:493961718 〈 10.10.10.1 〉 10.10.10.100: (frag 22666:48@2960+) (ttl 128)

A : 22666

B : 48

C : 2960+

정답 및 해설

IP 단편화 관련 tcpdump의 출력 형식은 'frag id:size@offset[+]' 이다. id는 단편화 전 원본 IP 데이터그램을 식별하기 위한 단편 ID를 의미하고, size는 ip 헤더를 제외한 단편의 크기로 바이트 단위로 표시한다. offset은 단편의 상대위치를 나타내며 +는 추가 단편이 있음을 의미하고 +가 없으면 마지막 단편을 의미한다.

A : 22666은 단편(Fragment) ID를 의미한다.

B : 48은 IP 헤더를 제외한 단편 크기(바이트 단위)를 의미한다.

C : 2960+는 단편의 상대위치(Offset)가 2960이고 추가 단편이 있음(+)을 의미한다.

0233. ○ △ × 16.1회.산기

MTU가 1,500바이트로 설정된 Ethernet을 통해 4,000바이트의 ping 패킷을 보내려고 한다. 단편화된 IP 패킷이 순서대로 전달된다고 가정할 때, 첫 번째 단편에서 전송되는 헤더를 제외한 실제 데이터의 크기를 구하시오.

정답 및 해설

첫 번째 IP 단편은 MTU에 따라 1,500바이트이며 이중 IP 헤더 20바이트를 제외한 부분이 데이터부가 된다.

정답 1,480바이트

0234. ○△×

다음 보기의 공격 기법을 쓰시오.

보기

1995년 유명한 해커 케빈 미트닉이 이론을 실제화하여 해킹을 시도하다가 체포된 사건이 있었다. 현재까지 TCP/IP 약점을 이용한 여러 가지의 공격 기법이 지속해서 나오고 있다. IP를 속여서 공격하는 기법을 의미한다.

정답 및 해설

- IP 스푸핑(Spoofing)은 트러스트 관계가 맺어져 있는 서버와 클라이언트를 확인한 후 클라이언트에 DoS 공격을 하여 연결을 끊는다. 그러고 나서 공격자가 클라이언트의 IP 주소를 확보하여 서버에 실제 클라이언트처럼 패스워드 없이 접근하는 공격이다. 트러스트 관계를 쓰지 않는 것이 최상의 대책이다.
- 트러스트 관계는 신뢰 관계에 있는 시스템 간에 별도의 로그인 없이 IP 기반의 인증을 수행하고 접속하는 방식을 말한다. 아이디, 패스워드를 쓰지 않기 때문에 스니핑 공격에 의한 노출을 막을 순 있지만 IP 스푸핑에는 취약한 문제점이 있다.

정답 IP 스푸핑(Spoofing)

0235. ○△× 17.2회.산기

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

IPv6 프로토콜은 IPv4 주소가 고갈되는 문제를 해결하기 위해 만들어진 128비트 체계의 인터넷 프로토콜 주소를 말한다. IPv4에서 IPv6로 전환을 위한 방식에는 터널링(Tunneling), 주소/헤더 변환(Address/Header Translation), ( ) 방식이 있다.

정답 및 해설

IPv4에서 IPv6로 전환하는 기술을 정리해 보면 다음과 같다.

- 듀얼스택(Dual Stack) : IPv4와 IPv6 프로토콜을 동시에 설정하여 통신 상대에 따라 선택적으로 사용할 수 있도록 하는 방식
- 터널링(Tunneling) : IPv4 네트워크를 경유하여 IPv6 네트워크 간 통신을 위한 방식으로 IPv4 네트워크를 통과하는 가상의 경로(터널)를 만들어 통신하는 방식
- 주소/헤더 변환(Address/Header Translation) : 변환 헤더를 추가하여 IPv4 주소를 IPv6 주소로 변환하거나 IPv6 주소를 IPv4 주소로 변환하여 통신하는 방식

정답 듀얼스택(Dual Stack)

0236. ○△×

TCP/IP 프로토콜 그룹에 속한 프로토콜로서, RFC 792에 의하여 규정되어 있으며, echo, timestamp, redirects 등을 비롯한 다양한 작업 유형의 메시지들이 제공되는 프로토콜을 쓰시오.

정답 및 해설

ICMP 프로토콜은 IP 프로토콜의 비 신뢰적인 특성을 보완하기 위한 프로토콜로 IP 패킷 전송 중 에러 발생 시 에러 발생 원인을 알려주거나 네트워크 상태를 진단해 주는 기능을 제공해 준다.

정답 ICMP(Internet Control Message Protocol)

0237. ○△×

ICMP 프로토콜은 두 호스트 간에 또는 하나의 호스트와 라우터 같은 네트워크 장비 사이에서 에러 메시지를 주고받을 때 사용된다. ICMP에서 악용되어 사용되는 ICMP 메시지 타입 중의 하나는 "ICMP Redirect" 메시지이다. ICMP Redirect 메시지는 호스트가 목적지 주소로 연결하고자 할 때, 해당 라우터가 최적의 경로를 호스트에게 다시 알려주기 위하여 (A)에서 (B)로 보내는 메시지로 공격자는 위조된 ICMP Redirect 메시지를 만들어 호스트의 라우팅 경로를 조작할 수 있다. 빈칸( )에 적절한 용어를 쓰시오.

정답 및 해설

ICMP Redirect 메시지는 일반적으로 라우터가 보내는 패킷으로 이를 수신한 호스트 또는 라우터는 자신의 라우팅 테이블에 특정 목적지로 나가는 gateway 주소를 변경한다. 보안상 이유로 대부분의 OS에서는 ICMP Redirect 옵션을 기본적으로 해제하고 있다.

정답 (A) 라우터 (B) 호스트

0238. ○△×

( )은/는 IP 멀티캐스트 그룹에서 호스트 멤버를 관리하는 프로토콜로써, IP 멀티캐스트 그룹은 특정 멀티캐스트 IP 주소로 전달되는 IP 트래픽을 감시하는 호스트들의 집합이다. 멀티캐스트 IP 트래픽은 하나의 MAC 주소로 보내지지만, 여러 개의 IP 호스트에 의해 처리된다. 지정된 호스트가 특정 IP 멀티캐스트 주소를 감시하고 그 IP 주소로 오는 모든 패킷을 받는다. 빈칸( )에 적절한 용어를 쓰시오.

정답 및 해설

- 멀티캐스트를 지원하는 라우터가 멀티캐스트 그룹에 가입한 네트워크 내의 호스트를 관리하기 위해 사용하는 프로토콜이다.
- IGMP는 ICMP와 마찬가지로 IP 상위 계층에 존재하며 IP 패킷으로 캡슐화되어 전송된다.

정답 IGMP(Internet Group Management Protocol)

0239. ○△× 25.1회.산기

전송 계층(Transport Layer)의 대표 프로토콜인 TCP 프로토콜의 헤더 구조에서 송신 포트 번호를 담고 있는 필드를 ( )라/이라 한다.

정답 및 해설

TCP 프로토콜의 헤더 구조에서 송신 포트 번호를 담고 있는 필드는 'Source Port(출발지 포트)'이고 수신 포트 번호를 담고 있는 필드는 'Destination Port(목적지 포트)'이다.

정답 Source Port(출발지 포트)

0240. ○△×

TCP 프로토콜에서 연결을 끊기 위해 설정할 수 있는 제어비트(제어 플래그)를 모두 쓰시오.

정답 및 해설

TCP 제어비트를 살펴보면 다음과 같다.

URG	▪ 긴급데이터 전송을 알리는 제어비트 ▪ URG 제어비트와 함께 Urgent Pointer 헤더 필드에 긴급데이터 위치정보를 설정한다.
ACK	▪ 상대방이 보낸 데이터가 정상 수신되었음을 알리는(수신 확인 응답) 제어비트 ▪ ACK 제어비트와 함께 Acknowledgment Number 헤더 필드에 상대방이 다음에 전송할 세그먼트의 순서번호(Sequence Number)를 설정한다.
PSH	▪ 송수신 데이터의 즉시 처리를 요청하는 제어비트 ▪ 송신 측 동작 : 송신 버퍼(send buffer)에 있는 데이터를 즉시 전송한다. ▪ 수신 측 동작 : 수신 버퍼(receive buffer)에 있는 데이터를 상위 애플리케이션으로 즉시 전달한다.
RST	▪ 연결 중단(초기화, 강제 종료)을 요청하는 제어비트
SYN	▪ 연결 설정을 요청하는 제어비트
FIN	▪ 연결 종료(정상 종료)를 요청하는 제어비트

정답 FIN, RST

0241. ○△×

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

( )은/는 특정 IP 주소와 포트 번호의 조합으로서 같은 IP의 동일한 시스템이 동시에 특정 클라이언트의 복수 개의 응용 프로그램에 정확하게 통신할 수 있게 해주는 기반을 제공해 주는 소프트웨어 모듈을 의미한다.

정답 및 해설

소켓(Socket)은 호스트/프로세스 간에 통신을 위한 소프트웨어 모듈을 의미한다. 네트워크 프로그램 작성 시 OS에서 제공해 주는 소켓 라이브러리를 이용하여 프로그래밍한다.

정답 소켓(Socket)

0242. ○△×

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

Well-Known 포트의 범위는 (A)이고, 통상적으로 23번 포트를 사용하는 (B), 25번 포트를 사용하는 (C)가 있다.

정답 및 해설

포트(Port)는 상위 애플리케이션/서비스/소켓을 식별하기 위한 식별자로 IANA(Internet Assigned Number Authority) 기구를 통해 관리되고 있다. 포트 분류 방식은 다음과 같다.

1) well-known port(0~1023번 포트)

- 잘 알려진 서비스에 할당된 포트로 관리자(root, administrator)가 서버 프로세스(데몬)를 실행하기 위해 사용하는 포트이다.
- 일반 사용자가 해당 포트를 사용하면 권한 문제가 발생한다.
- 주요 프로토콜별 포트 번호

프로토콜	포트번호	설명
FTP	20/tcp 21/tcp	▪ File Transfer Protocol, 파일 전송 프로토콜 ▪ 20/tcp(데이터 채널), 21/tcp(제어 채널)
SSH	22/tcp	Secure Shell, 암호화된 원격 터미널 접속 프로토콜
TELNET	23/tcp	TELe NETwork, 암호화하지 않은 원격 터미널 접속 프로토콜
SMTP	25/tcp	Simple Mail Transfer Protocol, 메일 전송 프로토콜
DNS	53/udp,tcp	Domain Name System, 도메인 정보 제공 프로토콜
DHCP	67/udp 68/udp	▪ Dynamic Host Configuration Protocol, 동적으로 호스트 네트워크 정보 설정 서비스를 제공하는 프로토콜 ▪ 67/udp(DHCP Server), 68/udp(DHCP Client)
TFTP	69/udp	Trivial File Transfer Protocol, 단순 파일 전송 프로토콜
HTTP	80/tcp	Hyper-Text Transfer Protocol, 하이퍼 문서 전송 프로토콜
POP3	110/tcp	Post Office Protocol version 3, 메일 수신 프로토콜
IMAP	143/tcp	Internet Message Access Protocol, 메일 수신 프로토콜
SNMP	161/udp 162/udp	▪ Simple Network Management Protocol, 네트워크 관리 프로토콜 ▪ 161/udp(SNMP 일반 메시지 전송, SNMP Agent) ▪ 162/udp(SNMP 트랩 메시지 전송, SNMP Manager)
HTTPS	443/tcp	HTTP over SSL/TLS, SSL/TLS 기반의 HTTP 프로토콜

2) Registered Port(1024~49151번 포트)

- 제조사(Vendor)가 IANA에 용도를 등록해서 사용하는 포트로 일반 사용자가 서버 프로세스(데몬)를 실행하기 위해 사용하는 포트이다.
- 대표적으로 DBMS에서 사용하는 포트를 들 수 있다.
  예) MySQL(3306/tcp), MS-SQL(1433/tcp), Oracle(1521/tcp)

3) Dynamic Port(49152~65535번 포트)

- 서버/클라이언트 환경에서 클라이언트 접속 시 사용하는 임시 포트(Ephemeral Port)

정답 (A) 0 ~ 1023 (B) Telnet (C) SMTP

0243. ○△×

다음의 빈칸 (A), (B)에 적절한 용어를 쓰시오.

보기

전송 계층에서 데이터 전송에 사용하는 프로토콜로 (A)은/는 연결 지향적이고 신뢰할 수 있는 특성이 있는 반면에 (B)은/는 비 연결형이고 신뢰성은 보장하지 못하지만, 상대적으로 가볍고 빠른 전송을 보장해준다.

정답 및 해설

답 (A) TCP (B) UDP

0244. ○△× 22.1회.기사 24.1회.기사

다음 보기에서 설명하는 공격 기법을 쓰시오.

보기

공격 대상 시스템에 접근할 수 있는 인증 정보(예: 아이디와 패스워드)를 모를 경우, 인증이 완료되어 정상적인 통신을 하는 사용자의 세션을 가로채 별도의 인증 없이 가로챈 세션으로 통신하는 공격 행위를 말한다.

정답 및 해설

세션 하이재킹(Session Hijacking) 공격은 '공격자가 인증이 완료된 정상적인 사용자 세션을 중간에 가로채서 별도의 인증 작업 없이 정상적인 사용자로 위장(가장)하여 가로챈 세션으로 통신하는 행위'를 말한다. 정상적인 사용자의 인증이 완료된 세션을 가로채기 때문에 강력한 사용자 인증기법(예: 일회성 패스워드(OTP), 시도/응답 기법 등)을 사용한다고 해도 이를 무력화할 수 있는 특징이 있다. 주요 공격 기법을 살펴보면 다음과 같다.

- TCP 세션 하이재킹(Session Hijacking) 공격 : TCP의 세션 관리 취약점을 이용한 공격으로 인증된 사용자의 세션 관리정보(출발지 IP/Port, Sequence Number 등)로 위조하여 TCP 세션을 가로채는 공격을 말한다.
- HTTP 세션 하이재킹(Session Hijacking) 공격 : HTTP의 세션 관리 취약점을 이용한 공격으로 인증된 사용자의 HTTP 세션 ID를 탈취하여 인증된 사용자로 위장하여 서버에 접근하는 공격을 말한다.

답 세션 하이재킹(Session Hijacking) 공격

0245. ○△×

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

( ) 공격은 TCP의 신뢰성을 기반으로 한 세션 관리의 취약점을 이용한 공격으로 정상적인 사용자 세션을 가로채 정상적인 인증과정을 무시하고 불법으로 시스템에 접근할 수 있다.

정답 및 해설

답 TCP 세션 하이재킹(Session Hijacking)

0246. ○△×

1995년 전설적인 해커 케빈 미트닉(Kevin Mitnick)이 시스템 관리자인 시모무라 쓰토무(Shimomura Tsutomu)의 컴퓨터 시스템을 공격할 때 세션을 가로채기 위해 IP 스푸핑(Spoofing)과 함께 사용한 공격 기법은 무엇인가?

정답 및 해설

TCP 세션 하이재킹(Session Hijacking)은 케빈 미트닉(Kevin Mitnick)이 시모무라 쓰토무의 컴퓨터 시스템을 공격할 때 사용했던 공격 방식으로 TCP의 세션 관리 취약점을 이용한 공격이다. TCP의 세션 식별정보를 공격자가 위조하여 세션을 탈취하는 방식으로 공격자는 정상적인 사용자의 출발지(Source) IP와 Port로 위조하고 순서번호(Sequence Number)를 예측하여 세션을 탈취하게 된다.

답 TCP 세션 하이재킹(Session Hijacking) 공격

0247. ○△× 24.4회.산기

다음은 네트워크 장비 취약점 점검 항목에 대한 설명이다. 빈칸( )에 적절한 용어를 보기에서 고르시오.

보기

ping, netstat, traceroute, keepalive, help, window

네트워크 장비의 Telnet 등 TCP 연결이 원격 호스트 측에 예상치 못한 장애로 비정상 종료되었을 때 네트워크 장비가 해당 연결을 지속하지 않고 해제하도록 TCP ( ) 서비스를 설정한다.

TCP ( ) 서비스는 TCP 연결이 유효한지 확인하기 위해 유휴 연결에 주기적으로 응답을 요구하는 패킷을 전송하고 원격 호스트가 일정 시간 동안 응답이 없으면 연결을 끊는다.

정답 및 해설

(네트워크 장비 보안 〉 기능 관리) TCP Keepalive 서비스 설정

1) 점검내용 : TCP Keepalive 서비스를 사용하는지 점검
   - TCP Keepalive 서비스 : TCP 연결이 유효한지 확인하기 위해 유휴 연결(장시간 송수신 패킷이 없는 연결)에 주기적으로 응답을 요구하는 패킷을 전송하고 원격 호스트가 일정 시간 동안 응답이 없으면 연결을 끊는 서비스
2) 점검목적 : 네트워크 장비의 Telnet 등 TCP 연결이 원격 호스트 측에 예상치 못한 장애로 비정상 종료된 경우 네트워크 장비가 해당 연결을 지속하지 않고 해제하도록 TCP Keepalive 서비스 설정
3) 보안위협 : 유휴 TCP 세션은 무단 접근 및 하이재킹 공격에 취약
4) 판단기준
   - 양호 : TCP Keepalive 서비스를 설정한 경우
   - 취약 : TCP Keepalive 서비스를 설정하지 않은 경우

※ 출처 : 주요정보통신기반시설 기술적 취약점 분석 · 평가 방법 상세가이드(과기정통부/KISA, 2021.3)

답 keepalive

관련지식

[VLAN(Virtual LAN) 기술]

1) 개요 17.2회.기사 24.4회.기사 15.1회.산기 23.4회.산기

① 일반적으로 하나의 스위치(L2 스위치) 장비는 하나의 LAN(서브넷)을 구성하는 장치들을 연결하기 위해 사용되는데 2개 이상의 가상의(논리적인) LAN(서브넷)을 구성할 수 있는 기능을 VLAN(Virtual LAN)이라 한다. 즉 스위치 장비가 제공하는 가상의 LAN을 구성하는 기능을 말한다.

② 데이터링크 계층(2계층)에서 브로드캐스트 도메인(Broadcast Domain)을 논리적으로 나누기 위해 사용하는 기술로 물리적인 네트워크 구조의 변경 없이 스위치에서 제공하는 기능을 통해 논리적으로 LAN(서브넷)을 구성할 수 있다.

③ (성능상의 장점) VLAN을 통해 가상의 브로드캐스트 도메인을 생성함으로써 브로드캐스트 트래픽을 제한하여 전체 네트워크 서비스의 성능향상을 기대할 수 있다.

④ (보안상의 장점) VLAN별로 서로 다른 보안 정책(네트워크 자원 접근제어)을 적용할 수 있으므로 보안성을 높일 수 있다. 예를 들어, 인사 부서가 강화된 보안을 요구한다면 관리자는 정책을 개발하고 모든 인사 부서 사용자들을 특정 VLAN에 추가하고 강화된 보안 정책을 인사 부서 VLAN에만 적용할 수 있다.

2) VLAN 종류 24.4회.기사 15.1회.산기

① Port 기반 VLAN : 스위치 포트를 각 VLAN에 할당하는 방식으로 같은 VLAN에 속한 포트에 연결된 호스트 간에만 통신이 가능한 VLAN이다. 가장 일반적이고 많이 사용되는 방식이다.

② MAC 기반 VLAN : 각 호스트의 MAC 주소를 VLAN에 등록하여 같은 VLAN에 속한 MAC 주소의 호스트 간에만 통신이 가능한 VLAN이다. 호스트의 MAC 주소를 전부 등록하고 관리해야 하는 어려움이 있다.

③ 네트워크 주소 기반 VLAN : 네트워크 주소별로 VLAN을 구성하여 같은 네트워크에 속한 호스트 간에만 통신이 가능한 VLAN이다. 주로 IP 네트워크 VLAN을 사용한다.

④ 프로토콜 기반 VLAN : 통신 프로토콜별로(TCP/IP, IPX/SPX, Netview 등) VLAN을 구성하여 같은 통신 프로토콜을 사용하는 호스트 간에만 통신이 가능한 VLAN이다.

3) VLAN 정보 할당 방식 23.4회.기사

① 정적 VLAN(Static VLAN) 방식 : 관리자가 직접 스위치의 모든 포트에 VLAN 정보를 할당하는 방식으로 VLAN 프레임을 처리해야 하는 모든 스위치마다 설정이 필요하다.

② 동적 VLAN(Dynamic VLAN) : VLAN 할당을 수행하는 별도의 장비(프로그램)를 사용하여 VLAN 정보를 자동으로 할당하는 방식으로 스위치 포트에 접속하는 장치의 MAC 주소에 따라 자동으로 VLAN을 할당한다.

0248. ○△× 24.4회.기사

다음 설명하는 용어를 보기에서 고르시오.

보기
Firewall, DHCP, NAC, SNMP, NAT, VLAN

- 데이터링크 계층에서 브로드캐스트 도메인(broadcast domain)을 나누기 위해 사용하는 기술로 물리적인 네트워크 구조의 변경 없이 스위치에서 제공하는 기능을 통해 논리적인 서브넷을 구성할 수 있다.
- 논리적인 서브넷에 서로 다른 보안 정책을 적용할 수 있으므로 보안성을 높일 수 있다.

정답 및 해설

정답 VLAN

0249. ○△×

다음은 VLAN(Virtual LAN)에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기
가상 랜(VLAN)은 물리적인 선 연결이 아닌 소프트웨어적으로 구성하는 LAN으로 경비와 시간 측면에서 효율적이고 네트워크 트래픽을 감소시킬 수 있으며 보안상 장점을 가지고 있다. VLAN을 구성하는 방법은 (A), (B), (C), (D) 또는 이것들의 조합에 근거한다.

정답 및 해설

정답 (A) Port 기반 (B) MAC 기반 (C) 네트워크 주소 (D) 프로토콜 기반

0250. ○△× 24.4회.기사

다음은 VLAN(Virtual LAN)에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기
(A) 기반 VLAN : 스위치 포트를 각 VLAN에 할당하는 방식으로 같은 VLAN에 속한 포트에 연결된 호스트 간에만 통신이 가능하다.
(B) 기반 VLAN : 호스트의 MAC 주소를 VLAN에 등록하는 방식으로 같은 VLAN에 속한 MAC 주소의 호스트 간에만 통신이 가능하다.
(C) 기반 VLAN : 네트워크 주소별로 VLAN을 구성하는 방식으로 같은 네트워크 주소에 속한 호스트 간에만 통신이 가능하다.
(D) 기반 VLAN : 통신 프로토콜별로 VLAN을 구성하는 방식으로 같은 통신 프로토콜을 사용하는 호스트 간에만 통신이 가능하다.

정답 및 해설

정답 (A) 포트 (B) MAC (C) 네트워크 주소 (D) 프로토콜

0251. ○ △ × 23.4회.기사

다음은 VLAN(Virtual LAN) 할당 방식에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

(A)	▪ 관리자가 직접 각 스위치에 VLAN을 할당하는 방식 ▪ 스위치의 각 포트에 원하는 VLAN을 배정
(B)	▪ VLAN 할당을 수행하는 별도의 장비를 이용하여 자동으로 설정하는 방식 ▪ 스위치 포트에 접속하는 장비의 MAC 주소에 따라 VLAN을 동적으로 배정

정답 및 해설

정답 (A) Static VLAN(정적 VLAN) (B) Dynamic VLAN(동적 VLAN)

0252. ○ △ × 25.1회.기사

다음은 VLAN(Virtual LAN) 관련 내용이다. 빈칸( )에 적절한 용어를 쓰시오.

(A)	▪ 관리자가 직접 각 스위치에 VLAN을 할당하는 방식 ▪ 스위치의 각 포트에 원하는 VLAN을 배정
(B)	▪ VLAN 할당을 수행하는 별도의 장비를 이용하여 자동으로 설정하는 방식 ▪ 스위치 포트에 접속하는 장비의 MAC 주소에 따라 VLAN을 동적으로 배정
(C)	▪ VLAN 정보를 확인할 수 있는 시스코(CISCO) 스위치 장비 명령어

정답 및 해설

시스코(CISCO) 스위치 장비에서 VLAN 정보를 확인하기 위해서는 show vlan(자세한 정보) 또는 show vlan brief (간략한 정보) 명령을 이용할 수 있다.

```
Switch>en
Switch#show vlan brief

VLAN Name                             Status    Ports
---- -------------------------------- --------- -------------------------------
1    default                          active    Fa0/1, Fa0/2, Fa0/3, Fa0/4
                                                Fa0/5, Fa0/6, Fa0/7, Fa0/8
                                                Fa0/9, Fa0/10, Fa0/11, Fa0/12
                                                Fa0/13, Fa0/14, Fa0/15, Fa0/16
                                                Fa0/17, Fa0/18, Fa0/19, Fa0/20
                                                Fa0/21, Fa0/22, Fa0/23, Fa0/24
                                                Gig0/1, Gig0/2
1002 fddi-default                     active
1003 token-ring-default               active
1004 fddinet-default                  active
1005 trnet-default                    active
Switch#
```

정답 (A) Static VLAN(정적 VLAN) (B) Dynamic VLAN(동적 VLAN) (C) show vlan(또는 show vlan brief)

0253. ○ △ × 17.2회.기사

다음은 VLAN(Virtual LAN)에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기

VLAN(Virtual LAN)은 네트워크 자원 접근을 제한함으로써 (A)을/를 높이고 브로드캐스트 도메인의 (B)을/를 줄여서 브로드캐스트 트래픽 양을 줄이는 효과가 발생하고 결과적으로 전체 네트워크 서비스의 (C)을/를 향상시킬 수 있다.

정답 및 해설

VLAN(Virtual LAN)을 사용하는 이유를 정리하면 다음과 같다.

1. 보안 강화 : 네트워크 관리자는 서로 다른 논리적인 그룹에 대하여 서로 다른 보안 정책을 적용할 수 있다.
2. 성능 향상 : 브로드캐스트 도메인의 크기/범위를 줄여 네트워크 성능향상을 기대할 수 있다.

정답 (A) 보안성 (B) 크기/범위 (C) 성능

0254. ○ △ × 23.4회.산기 25.2회.산기

다음 보기의 문제점을 해결하기 위한 스위치(switch) 장비의 기술을 보기에서 고르시오.

보기

STP, VTP, VLAN, NAC, NAT, SPAN

- PC1, PC2, PC3가 같은 스위치(Switch)에 연결되어 있다. PC1이 PC2의 MAC 주소를 알아내기 위해 ARP 요청 브로드캐스트 프레임을 전송하면 스위치는 해당 프레임을 플러딩(Flooding)하게 된다. 따라서 불필요하게 PC3는 브로드캐스트 프레임 처리를 위한 자원을 소모하게 된다.
- 스위치에 연결된 장비가 많을수록 브로드캐스트 프레임이 증가하여 네트워크 성능 저하가 발생한다.
- 웜이나 바이러스에 감염된 호스트가 발생하면 같은 브로드캐스트 도메인 내에 있는 호스트로 쉽게 확산되는 문제점이 있다.

정답 및 해설

스위치(L2 Switch)의 포워딩(Forwarding) 및 플러딩(Flooding) 기능

- 포워딩 기능 : 스위치의 MAC Address Table을 참조하여 전송할 프레임의 목적지 MAC 주소의 장치가 연결된 포트로 프레임을 전달하는 기능
- 플러딩 기능 : 프레임이 유입된 포트를 제외한 장치가 연결된 모든 포트로 프레임을 전송하는 기능으로 프레임의 목적지 MAC 주소가 브로드캐스트 또는 멀티캐스트 주소이거나 MAC Address Table에 없는 경우 등에 발생한다.

정답 VLAN

0255. ○△×

다음 보기에서 설명하는 기술의 명칭을 쓰시오.

보기

보유하고 있는 IP 주소가 부족한 경우, 사설 IP 주소를 사용하여 IP 주소를 확장하는 방법으로 이를 이용하면 내부 네트워크의 사설 IP 주소는 외부에 공개되지 않으므로 외부의 공격으로부터 비교적 안전한 네트워크 환경을 구성할 수 있다.

정답 및 해설

- NAT(Network Address Translation, 네트워크 주소 변환)는 사설망(기관/회사, 가정 등)에서 사용하는 사설 IP(Private IP) 주소와 인터넷에서 사용하는 공인 IP(Public IP) 주소 간 변환 기술을 말한다.
- (NAT 미설정 시 보안 위협) NAT 설정을 하지 않으면 인터넷에서 공인 IP 주소를 통해 시스템에 접근할 수 있어 정보 유출, 시스템 파괴, 악성코드 전파 등의 불법적 행위가 발생할 수 있다.
- (NAT 사용 목적) 부족한 공인 IP(IPv4) 주소를 절약할 수 있고 사설 IP 주소는 인터넷에 공개되지 않으므로(인터넷을 통해 직접 접속할 수 없으므로) 인터넷으로부터의 내부 시스템 공격에 안전한 네트워크 환경을 구축할 수 있다.

정답 NAT(Network Address Translation)

0256. ○△× 24.2회.산기

다음 빈칸( )에 들어갈 용어를 보기에서 고르시오.

보기

공인, 사설, 위협, 취약점, 보안, 악성코드

NAT(Network Address Translation) 설정을 하지 않으면 (A) IP를 통해 시스템에 접근할 수 있어 정보 유출, 시스템 파괴, (B) 전파 등의 불법적인 행위가 발생할 수 있다.

정답 및 해설

정답 (A) 공인 (B) 악성코드

0257. ○△×

다음과 같은 NAT(Network Address Translation) 환경에서 서버 B에서 보는 서버 A의 IP 주소를 쓰시오.

보기

A ---- [A-Gateway] ---- {인터넷} ---- [B-Gateway] ---- B

- A-호스트 IP(사설 IP) : 172.16.5.163
- B-호스트 IP(사설 IP) : 192.168.56.100
- A-Gateway IP(공인 IP) : 211.241.82.100
- B-Gateway IP(공인 IP) : 210.112.54.1

정답 및 해설

NAT는 IP 주소 변환 장비(일반적으로 라우터 또는 방화벽을 이용함)의 인터페이스 IP로 변환된다.

정답 211.241.82.100

0258. ○△×

ICMP Echo Request 메시지를 대상 호스트에 전송하여 이에 대한 ICMP Echo Reply 메시지를 수신함으로써 대상 호스트의 활성화 여부 및 종단 구간의 네트워크 상태를 점검할 수 있는 명령어를 쓰시오.

정답 및 해설

ping 명령은 대상 시스템에 대한 접근성 및 대상 호스트와의 네트워크 구간에 대한 속도(왕복 시간) 및 품질(손실률) 등을 점검하기 위해 사용하는 명령이다.

정답 ping

0259. ○△×

공격자의 시스템 침입 경로를 확인하는 방법 중에서 공격자가 현재 시스템과 통신하고 있는지를 확인하고자 한다. 현재 연결된 모든 세션 상태를 확인할 수 있는 유닉스/리눅스/윈도우 시스템의 내장 명령어를 쓰시오.

정답 및 해설

netstat 명령은 시스템의 네트워크 관련 다양한 상태정보를 확인할 수 있는 유닉스/리눅스/윈도우 시스템의 내장 명령이다. 소켓 상태정보(네트워크 연결 상태정보), 네트워크 인터페이스 정보, 라우팅 테이블 정보, 프로토콜별 통계 정보 등 지정한 옵션에 따라 다양한 네트워크 상태정보를 제공한다.

정답 netstat

0260. ○△×

다음은 리눅스 시스템에서 명령을 수행한 결과이다. 명령어와 상세 옵션을 쓰시오.

```
[root@localhost ~]# (          )
Active Internet connections (servers and established)
Proto Recv-Q Send-Q Local Address          Foreign Address        State
tcp        0      0 0.0.0.0:44867         0.0.0.0:*              LISTEN
tcp        0      0 0.0.0.0:3306          0.0.0.0:*              LISTEN
tcp        0      0 0.0.0.0:111           0.0.0.0:*              LISTEN
tcp        0      0 0.0.0.0:22            0.0.0.0:*              LISTEN
tcp        0      0 127.0.0.1:631         0.0.0.0:*              LISTEN
tcp        0      0 127.0.0.1:25          0.0.0.0:*              LISTEN
tcp        0      0 192.168.197.133:23    192.168.197.1:3473     ESTABLISHED
```

정답 및 해설

명령의 결과를 살펴보면 netstat 명령을 통해 TCP 소켓(연결) 상태정보를 출력하고 있으면 상세 옵션을 살펴보면 다음과 같다.

- 연결 중이거나(ESTABLISHED 상태) 연결 대기 중인(LISTEN 상태) 모든 소켓 상태정보를 출력하고 있으므로 '-a' 옵션을 사용함
- TCP 소켓 상태정보만 출력하고 있으므로 '-t' 옵션을 사용함
- 네트워크 주소(IP 주소, 포트 번호) 정보를 호스트명(도메인명) 또는 서비스명이 아닌 숫자 형식으로 출력하고 있으므로 '-n' 옵션을 사용함

정답 netstat -ant

0261. ○△× 22.1회.산기 24.2회.산기

알기사 교육기관의 보안관제 담당자는 DMZ 구간에 있는 특정 리눅스 서버가 주기적으로 의심스러운 '중국 IP'에 접속한 사실을 확인하였다. 침해사고 분석을 위해 해당 리눅스 서버의 어떤 프로세스가 접속을 시도하는지 확인하고자 한다. 리눅스 서버에서 제공하는 명령어만을 이용하여 명령어를 작성하시오.

정답 및 해설

리눅스 시스템의 netstat 명령 소켓 관련 주요 옵션은 다음과 같다.

- -a 옵션 : 연결 중이거나 연결 대기 중인(리스닝) 모든 소켓 상태정보 출력
- -n 옵션 : 네트워크 주소(IP 주소, 포트 번호) 정보를 숫자 형식으로 출력
- -t 또는 -u 옵션 : -t는 TCP 소켓(연결) 상태정보, -u는 UDP 소켓(연결) 상태정보 출력
- -p 옵션 : 소켓을 생성한 프로세스의 PID(Process ID)와 프로그램명(실행파일명) 출력

10.10.10.10 IP와 연결된 프로세스(nc) 확인 예

```
[root@Fedora11 ~]# netstat -anp | grep "10.10.10.10"
tcp    0    0    192.168.56.100:33620    10.10.10.10:8080    ESTABLISHED    8538/nc
```

Local Address | Foreign Address | State | PID/Program name

정답 netstat -anp | grep "중국 IP"

0262. ○△×

다음은 리눅스/유닉스 시스템에서 제공하는 네트워크 관리 명령의 실행 결과이다. 어떤 명령을 실행한 결과인지 쓰시오.

```
root@CentOS9S2:~
[root@CentOS9S2 /root]# (    명령어    ) www.kisa.or.kr
traceroute to www.kisa.or.kr (58.235.102.10), 30 hops max, 60 byte packets
 1  * * *
 2  100.71.58.181 (100.71.58.181)  5.546 ms  6.440 ms  6.366 ms
 3  100.71.37.5 (100.71.37.5)  3.901 ms  3.858 ms 100.71.37.9 (100.71.37.9)  2.690 ms
 4  10.44.249.30 (10.44.249.30)  15.487 ms 10.44.249.38 (10.44.249.38)  2.550 ms 10.44.
 5  10.222.18.124 (10.222.18.124)  2.440 ms 10.222.18.134 (10.222.18.134)  15.209 ms 10
 6  10.222.15.85 (10.222.15.85)  3.330 ms 10.222.15.81 (10.222.15.81)  1.467 ms 10.222.
 7  211.201.158.14 (211.201.158.14)  1.279 ms  1.197 ms 211.201.158.22 (211.201.158.22)
 8  58.235.102.10 (58.235.102.10)  1.314 ms  1.225 ms  2.140 ms
[root@CentOS9S2 /root]#
```

정답 및 해설

traceroute/tracert 네트워크 관리 명령

- 종단(End, 최초 출발지와 최종 목적지) 구간 사이에 경로(경유지)를 추적하기 위한 명령
- 종단 사이에 있는 중계 노드(라우터, L3 장비)를 식별하고 각 구간에 대한 네트워크 상태를 점검하기 위한 명령으로 네트워크 라우팅 문제점을 찾아내는 목적으로 주로 사용한다.
- 경유 구간에 있는 중계 노드(라우터, L3 장비)의 개수 및 IP 주소, 구간별 왕복 시간(RTT : Round Trip Time) 등을 점검할 수 있다.
- 유닉스/리눅스의 경우 traceroute 명령을 기본으로 제공하고 윈도우의 경우 tracert 명령을 기본 제공한다.

정답 traceroute

0263. ○△× 15.1회.산기 23.1회.산기

다음의 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

> 보기
>
> traceroute 명령은 목적지까지 패킷 도달 여부를 확인하는 도구로서 목적지까지 진행 경로를 추적한다. 처음에는 IP 패킷의 (A) 필드값이 1인 패킷을 보내게 된다. 그러면 이 패킷이 도달한 라우터에서는 (A) 필드값이 감소하게 되고 (B) 프로토콜에 의해 시간초과(Time Exceeded) 오류 메시지를 출발지로 보내게 된다. 다음은 (A) 필드값이 (C)인 패킷을 보내어 라우터 정보를 얻어오는 방식을 반복함으로써 최종 목적지까지의 경로를 확인할 수 있다.

정답 및 해설

traceroute 명령(유닉스/리눅스 기본 제공)의 특징을 정리해 보면 다음과 같다.

- (원리) IP 패킷의 TTL 값을 1씩 증가시키면서 경로 확인
- (패킷) UDP 패킷을 사용하며 목적지 포트로 33434 이상 UPD 포트(닫힌 포트) 사용
- (TTL 초과 시 응답) ICMP Time Exceeded 메시지(코드 : TTL exceeded in transit)
- (목적지 호스트 도달 시 응답) ICMP Destination Unreachable 메시지(코드 : Port Unreachable)

정답 (A) TTL (B) ICMP (C) 2

0264. ○△× 17.2회.산기

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

(A)은/는 네트워크 진단 도구로 네트워크 라우팅 문제점을 찾아내는 목적으로 많이 사용된다. IP 헤더의 TTL 필드의 값을 1씩 증가시킨 UDP 패킷들을 반복적으로 전송하여 경유 구간에 있는 라우터의 개수, IP 주소, 응답 시간을 출력한다. 최초 TTL=1인 UDP 패킷은 첫 번째 라우터에서 TTL이 1 감소하여 0이 되고 해당 패킷이 폐기되었음을 알리는 ICMP Time Exceeded 메시지가 최초 출발지로 전송된다. 두 번째 TTL=2인 UDP 패킷은 두 번째 라우터에서 폐기되며 최종 목적지에 도달할 때까지 계속 TTL을 증가시키면서 UDP 패킷을 전송한다. 이러한 패킷들은 사용하지 않는 UDP 포트(33434 이상)를 목적지 포트로 사용하기 때문에 최종 목적지에 도달하면 최초 출발지로 ICMP Destination Unreachable(type: 3)/Port Unreachable (Code:3) 메시지를 전송하고 해당 메시지를 수신하면 최종 목적지에 도달했음을 알 수 있다.

정답 및 해설

네트워크 진단 도구인 traceroute와 tracert는 동작 원리는 동일하지만, 구현 방식에 차이가 있다. 유닉스/리눅스 시스템에서 기본 제공하는 traceroute 명령은 목적지 호스트의 특정 포트(33434/udp 이상)로 UDP 패킷의 TTL 값을 1씩 증가시키면서 진단하고 윈도우 시스템에서 기본 제공하는 tracert 명령은 목적지 호스트로 ICMP Echo Request 패킷의 TTL 값을 1씩 증가시키면서 진단한다.

정답 traceroute

0265. ○△× 17.1회.산기

다음은 네트워크 진단에 사용하는 윈도우 시스템의 유틸리티 프로그램에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기

(A)은/는 점검용 호스트에서 목적지 호스트까지 경유하게 되는 L3 장비(라우터 등)의 개수, IP 주소, 구간별 응답 시간 등 네트워크 상태를 점검하기 위한 윈도우 유틸리티 프로그램이다. 그 동작 원리는 다음과 같다.
첫 번째 L3 장비 구간의 네트워크 상태 점검을 위해 (B) 프로토콜을 사용하여 패킷을 전송하는데 이때 IP 헤더의 (C) 필드값을 1로 설정한다. 해당 패킷이 첫 번째 L3 장비에 도착하면 (C) 필드값이 1 감소하여 0이 되며 L3 장비는 (C) 필드값이 0인 패킷을 폐기하면서 (B) 프로토콜을 이용하여 최초 출발지로 패킷이 폐기되었음을 알린다. 이 과정을 통해 L3 장비의 IP 주소와 구간 상태를 점검할 수 있으면 (C) 필드값을 1씩 증가시킴으로써 이후의 L3 장비들을 점검할 수 있다.

정답 및 해설

tracert 명령(윈도우 기본 제공)의 특징을 정리해 보면 다음과 같다.

- (원리) IP 패킷의 TTL 값을 1씩 증가시키면서 경로 확인
- (패킷) ICMP Echo Request 메시지 사용
- (TTL 초과 시 응답) ICMP Time Exceeded 메시지(코드 : TTL exceeded in transit)
- (목적지 호스트 도달 시 응답) ICMP Echo Reply 메시지

정답 (A) tracert (B) ICMP (C) TTL

0266. ○△× 21.1회.산기

다음 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

(A) 프로토콜은 시스템 또는 네트워크 장비 간에 메시지 전송 및 오류 발생 시 에러 메시지를 통보해주는 역할을 하는 프로토콜로 이를 이용한 대표적인 네트워크 진단 도구로 (B)과/와 (C)이/가 있다.
(B)은/는 ICMP Echo Request와 ICMP Echo Reply 메시지를 이용하여 대상 호스트의 활성화 여부를 검사하는 데 주로 사용하며 (C)은/는 대상 호스트 사이에 있는 중계 구간의 라우터 주소를 표시해 주며 목적지까지 도달하는데 경유하는 네트워크 경로 정보를 확인하는 데 주로 사용한다.

정답 및 해설

- IP 프로토콜은 최선의 노력(Best Effort) 원칙에 따른 전송 기능을 제공하기 때문에 IP 패킷이 목적지에 전달되지 못할 수도 있고, 전달되더라도 원하는 서비스 포트가 존재하지 않는 경우도 발생할 수 있다. 이러한 IP의 비신뢰적인 특성을 보완해 주기 위한 프로토콜이 ICMP 프로토콜이다.
- ICMP 프로토콜은 오류 보고 메시지(Error-Report Message)와 상태 진단 메시지(Query Message)를 통해 IP 프로토콜에 대한 보조적인 역할을 한다.
- traceroute 명령은 주로 유닉스/리눅스 시스템에서 중계 라우터 구간별 네트워크 상태를 진단하기 위해 사용하는 도구이다. UDP 프로토콜을 이용하여 특정 포트로(default 33434/udp 이상) IP 패킷의 TTL값을 1씩 증가시키면서 전송하고 ICMP Time Exceeded 메시지 응답을 통해 상태를 진단하게 된다. 최종 목적지에 도달하면 해당 UDP 포트가 닫혀 있으므로 ICMP Destination Unreachable 메시지를 수신하게 된다.
- tracert 명령은 주로 윈도우 시스템에서 중계 라우터 구간별 네트워크 상태를 진단하기 위해 사용하는 도구이다. ICMP 프로토콜을 이용하여 ICMP Echo Request 메시지를 IP 패킷의 TTL값을 1씩 증가시키면서 전송하고 ICMP Time Exceed 메시지 응답을 통해 상태를 진단하게 된다. 최종 목적지에 도달하면 ICMP Echo Reply 메시지를 수신하게 된다.

정답 (A) ICMP (B) ping (C) traceroute 또는 tracert

0267. ○△×

다음 보기에서 설명하는 기법의 명칭을 쓰시오.

보기

공격자가 침입 전 대상 시스템에 어떤 포트(서비스)가 활성화되어 있는지 확인하는 기법으로 공격뿐만 아니라 모의 침투 및 취약점 분석을 위한 사전 조사 작업 중 하나이다. 해당 기법을 통해 대상 호스트의 동작 여부와 제공되는 서비스(예: HTTP, SSH, DNS 등) 등을 식별할 수 있다.

정답 및 해설

정답 포트 스캔(Port Scan) 기법

0268. ○ △ × 17.2회.기사 16.2회.산기

취약점 분석을 위한 사전 작업 중 하나인 포트 스캔(Port Scan) 기법 중 포트가 열린 경우에는 아무런 응답이 없고 닫힌 경우에만 서버로부터 RST 응답 패킷이 오는 스캔 기법을 세 가지 쓰시오.

정답 및 해설

TCP FIN, NULL, Xmas 스캔은 TCP 패킷 헤더의 제어 플래그를 비정상적인 조합으로 설정하여 스캔하는 방식으로, TCP 표준(RFC 793)의 동작 특성을 이용해 포트 오픈 여부를 확인한다.

- 닫힌 포트로 RST 이외의 패킷이 수신되면 RST 패킷으로 응답한다.
- 열린 포트로 SYN, ACK, RST 이외의 패킷이 수신되면 이를 폐기하고 응답하지 않는다.

따라서 위와 같은 TCP 표준 동작 방식을 준수하는 시스템이라면 해당 스캔에서 사용하는 패킷에 대해 닫힌 포트에서만 RST 패킷으로 응답하고 열린 포트에서는 응답하지 않는다.

정답 TCP FIN 스캔, TCP NULL 스캔, TCP Xmas 스캔

0269. ○ △ × 14.2회.기사

다음 중 TCP 포트가 닫힌 경우에만 패킷이 되돌아오는 원리를 이용한 포트 스캔 방법을 모두 고르시오.

보기

TCP SYN 스캔, TCP FIN 스캔, TCP Xmas 스캔, TCP NULL 스캔, Decoy 스캔

정답 및 해설

1) TCP FIN/NULL/Xmas 스캔은 비정상적인 TCP 플래그 조합을 이용한 스캔 방식으로, 포트 상태에 따라 다음과 같은 응답 특성을 가진다. 이러한 특성으로 인해 포트가 닫힌 경우에만 패킷이 되돌아오는 원리를 이용한다.
   - 열린 포트 : 응답 없음
   - 닫힌 포트 : RST+ACK 응답 수신
2) TCP SYN 스캔은 포트가 열린 경우 SYN+ACK, 닫힌 경우 RST/+CK 응답이 수신되므로 해당 조건에 부합하지 않는다.
3) Decoy 스캔은 스캔 기법이 아니라, 실제 스캐너 IP 외에 여러 개의 가짜 IP 주소를 함께 사용하여 스캔을 수행하는 옵션으로, 응답 패킷의 유무와는 직접적인 관련이 없다.

정답 TCP FIN 스캔, TCP NULL 스캔, TCP Xmas 스캔

0270. ○ △ × 24.4회.기사

다음 보기의 포트 스캔 기법 중 포트가 열린 경우에는 응답이 없고 닫힌 경우에만 응답이 오는 스캔 기법을 모두 고르시오.

보기

TCP SYN Scan, TCP FIN Scan, TCP NULL Scan, TCP Xmas Scan, Decoy Scan

정답 및 해설

정답 TCP FIN Scan, TCP NULL Scan, TCP Xmas Scan

0271. ○ △ × 13.2회.산기 22.4회.산기 24.2회.산기

세션을 완전히 성립하지 않은 상태에서 대상 시스템의 포트 활성화 여부를 확인하므로, 일반적인 연결 로그가 남지 않는 스캔 방식이다. 이로 인해 공격 대상 시스템의 관리자는 스캔을 수행한 공격자의 IP 주소를 식별하기 어렵다. 대표적인 형태로 TCP SYN(Half-Open) 스캔이 있는 이 스캔의 유형은 무엇인가?

정답 및 해설

스텔스 스캔(Stealth Scan) 방식은 TCP 세션이 완전히 성립되지 않은 상태에서(TCP 연결 설정 미완료 상태) 대상 시스템의 포트 오픈 여부를 확인하는 스캔 방식이다. TCP 연결 설정이 완전히 이루어지지 않기 때문에 연결 로그가 남지 않는 특성이 있으며, 이러한 특성으로 인해 공격 대상 시스템의 관리자는 스캔을 수행한 공격자의 IP 주소를 식별하기 어렵다.

대표적인 스텔스 스캔 방식으로 TCP SYN 스캔, TCP FIN 스캔, TCP NULL 스캔, TCP Xmas 스캔 등이 있다.

정답 스텔스 스캔(Stealth Scan)

0272. ○ △ × 15.2회.산기

세션이 완전히 성립되지 않은 상태에서 공격 대상 시스템에 포트 활성화 여부를 알아내기 때문에 대상 시스템에 연결 로그가 남지 않는다. 대표적으로 TCP FIN 스캔 공격이나 TCP Xmas 스캔 공격이 이에 해당한다. 이처럼 공격자가 자신의 IP 주소를 노출하지 않는 스캔 방식을 무엇이라 하는가?

정답 및 해설

정답 스텔스 스캔(Stealth Scan)

0273. ○ △ ×

TCP SYN 스캔은 Full TCP 연결을 하지 않으므로 Half-Open 스캔이라 한다. 하나의 SYN 패킷을 전송하여 SYN+ACK 제어 플래그 응답이 오면 해당 포트는 열린 상태이며, ( ) 제어 플래그 응답이 오면 닫힌 상태를 나타낸다. 빈칸 ( )에 들어갈 적절한 용어를 쓰시오.

정답 및 해설

TCP SYN(Half-Open) 스캔의 동작 방식은 다음과 같다.

1) 대상(Target) 호스트의 지정한 포트로 SYN 패킷을 전송한 후, 포트 오픈 여부에 따라 다음과 같은 응답 패킷을 수신한다.
   - 열린 포트 : SYN+ACK 응답 수신
   - 닫힌 포트 : RST+ACK 응답 수신
2) 지정한 포트가 열린 경우 SYN+ACK 응답만으로도 포트의 활성화 여부를 확인할 수 있으므로, TCP 연결을 완료하지 않기 위해 RST 패킷을 전송하여 연결 설정을 즉시 중단한다.

정답 RST+ACK

0274. ○ △ × 21.1회.산기

다음 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

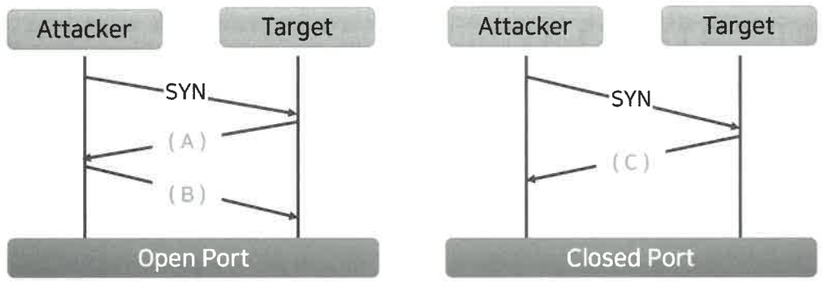
TCP Half-Open 스캔 시 공격자는 먼저 (A) 패킷을 전송하고 대상 호스트의 응답을 기다린다. 대상 호스트의 포트가 열린 경우 (A) + (B) 플래그가 설정된 패킷 응답을 수신하며, 공격자는 즉시 (C) 패킷을 전송하여 연결을 중단한다. 대상 호스트의 포트가 닫힌 경우에는 RST+ACK 패킷 응답을 수신한다.

정답 및 해설

정답 (A) SYN (B) ACK (C) RST

0275. ○ △ × 23.1회.산기

다음은 포트 스캔 방식 중 TCP Half-Open 스캔(SYN 스캔) 동작 방식에 대한 설명이다. 빈칸( )에 적절한 제어 플래그(비트)를 쓰시오.



정답 및 해설

정답 (A) SYN+ACK (B) RST (C) RST+ACK

0276. ○ △ × 17.2회.산기

다음의 빈칸( )에 적절한 TCP 제어 플래그를 쓰시오.

보기

TCP 기반의 포트 스캐(Port Scan) 기법 중 TCP Connect(Open) 스캔 기법은 최초 (A) 플래그를 설정하여 타깃 시스템에 패킷을 전송한다. 만약 타깃 시스템의 포트가 열린 상태이면 (A)과/와 (B) 플래그가 설정된 응답을 수신하고 연결 설정 완료를 위한 (B) 플래그 패킷을 전송한다. 이와 달리 TCP SYN(Half-Open) 스캔 공격은 타깃 시스템의 열린 포트에 대해 (A)과/와 (B) 플래그가 설정된 응답 수신 후 (C) 플래그 패킷을 전송하여 연결 설정을 즉시 중단한다.

정답 및 해설

정답 (A) SYN (B) ACK (C) RST

0277. ○ △ × 15.2회.기사

TCP Open 스캔 공격에서 포트가 닫혀 있는 경우라면 공격자 시스템과 목표 시스템 간에는 어떤 종류의 패킷 신호를 주고받는지 빈칸( )을 채우시오.

□ TCP Open 스캔 공격 시

- 공격자 시스템 → 목표 시스템 : (A) 패킷
- 목표 시스템 → 공격자 시스템 : (B) 패킷

TCP Half-Open 스캔 공격에서 포트가 열려있는 경우라면, 공격자 시스템과 목표 시스템 간에는 어떤 종류의 패킷 신호를 주고받는지 빈칸( )을 채우시오.

□ TCP Half-Open 스캔 공격 시

- 공격자 시스템 → 목표 시스템 : (C) 패킷
- 목표 시스템 → 공격자 시스템 : (D) 패킷
- 공격자 시스템 → 목표 시스템 : (E) 패킷

정답 및 해설

정답 (A) SYN (B) RST+ACK (C) SYN (D) SYN+ACK (E) RST

0278. ○ △ × 21.2회.산기

다음 보기는 포트 스캔(Port Scan) 공격의 결과이다. 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

- TCP Open(Connect) 스캔 공격 시 대상 호스트 포트가 닫힌 상태일 때 (A) 패킷 응답이 반환된다.
- TCP Half-Open(SYN) 스캔 공격 시 대상 호스트 포트가 닫힌 상태일 때 (B) 패킷 응답이 반환된다.
- TCP NULL 스캔 공격 시 대상 호스트 포트가 닫힌 상태일 때 (C) 패킷 응답이 반환된다.

정답 및 해설

각각의 포트 스캐닝 공격 결과를 정리하면 다음과 같다.

스캔 공격	열린 포트 응답	닫힌 포트 응답
TCP Open(Connect) 스캔	SYN+ACK	RST+ACK
TCP Half-Open(SYN) 스캔	SYN+ACK	RST+ACK
TCP FIN/NULL/Xmas 스캔	응답 없음	RST+ACK

정답 (A) RST+ACK (B) RST+ACK (C) RST+ACK

0279. ○△×

다음 보기의 수집된 패킷으로 유추할 수 있는 공격 명칭을 쓰시오.

보기

22:35:39.282312 172.16.0.3:2543 〉 172.16.0.3:http SW 674719801:674719801(0) win 65535
22:35:49.282312 172.16.0.3:1943 〉 172.16.0.3:http SW 674719801:674719801(0) win 65535
22:35:59.282312 172.16.0.3:1822 〉 172.16.0.3:http SW 674719801:674719801(0) win 65535

정답 및 해설

패킷을 분석해 보면, 출발지 IP 주소와 목적지 IP 주소가 동일한(172.16.0.3) 여러 개의 패킷이 반복적으로 전송되고 있다. 이는 출발지 IP 주소를 목적지 IP(대상 시스템의 IP)와 동일하게 위조한 패킷을 전송하여, 대상 시스템이 자기 자신에게 응답을 보내는 비정상 동작을 유발함으로써 무한 루프(Loop) 상태 또는 과도한 자원 소모를 일으키는 서비스 거부(DoS) 공격인 Land 공격의 전형적인 특징이다. 따라서 이는 Land 공격으로 판단할 수 있다.

답 Land 공격

0280. ○△× 22.4회.산기

다음 보기의 공격 명칭을 쓰시오.

보기

공격자가 패킷의 출발지 주소를 목적지 주소와 동일하게 설정하여 공격 대상 컴퓨터에 전송하는 공격으로 해당 공격을 당하게 되면 컴퓨터의 실행 속도가 느려지거나 동작이 마비되어 정상적인 서비스가 불가능한 상태가 된다. 공격에 대응하기 위해서는 출발지 주소와 목적지 주소가 동일한 패킷을 차단한다.

정답 및 해설

답 Land 공격

0281. ○△×

IP 단편화(Fragmentation)는 이기종 네트워크 환경에서 IP 패킷의 효율적인 전송을 보장해 주고 있지만 이러한 IP 단편화를 악용한 공격 기법들이 있다. 아래 설명하고 있는 IP 단편화를 이용한 공격 기법은 무엇인가?

보기

공격자는 첫 번째 IP 단편에 패킷 필터링 장비가 허용하는 포트 번호(예: HTTP 80/tcp)를 포함시킨다. 그 다음 두 번째 단편의 오프셋(Fragment Offset)을 조작하여, 단편들이 재조합되는 과정에서 두 번째 단편의 포트 번호가 첫 번째 단편의 포트 번호 위치를 덮어쓰도록(overlap) 하는 공격 기법이다.

정답 및 해설

Fragment overlap 공격(단편 중첩 공격)은 IP 단편의 오프셋(Fragment Offset) 값을 조작하여, 두 번째 단편이 첫 번째 단편의 일부를 덮어쓰도록 만들어 패킷 필터링 장비를 우회하는 공격 기법이다. 공격방식은 다음과 같다.

1) 공격자는 두 개의 IP 단편을 생성하여, 첫 번째 단편에는 필터링 장비가 허용하는 포트 정보(예: 443/tcp)를 포함시킨다.
2) 두 번째 단편에는 공격자가 실제로 접속하려는 차단 대상 포트 정보(예: 22/tcp)를 포함시키고, 이 단편이 첫 번째 단편의 목적지 포트 필드를 덮어쓰도록 오프셋 값을 조작한다.
3) 취약한 패킷 필터링 장비는 첫 번째 단편에 포함된 허용 포트 정보(예: 443/tcp)만을 검사하고 허용한 뒤, 같은 흐름의 두 번째 단편 역시 통과시킨다.
2) 대상 시스템에서는 두 단편이 재조합되어 결과적으로 공격자가 의도한 포트(예: 22/tcp)로 연결이 이루어진다.

답 Fragment overlap 공격

0282. ○△×

TCP 헤더 부분을 아주 작게 만들어서 패킷 필터링 장비(방화벽, IDS/IPS 등)를 우회하는 공격으로 목적지 서버에서는 이 패킷들이 재조합되어 공격자가 원하는 포트의 프로그램으로 연결하는 공격 기법은 무엇인가?

정답 및 해설

Tiny fragment 공격(작은 단편 공격)은 TCP/UDP 헤더가 두 개의 IP 단편으로 나누어질 정도로 첫 번째 단편을 매우 작은 크기로 생성하여 패킷 필터링 장비를 우회하는 공격 기법이다. 공격방식은 다음과 같다.

1) 공격자는 TCP/UDP 헤더가 두 개의 IP 단편에 나누어지도록 패킷을 아주 작은 단편으로 쪼개어 전송한다. 이때 첫 번째 단편에는 목적지 포트 정보가 포함되지 않도록 하고, 두 번째 단편에 목적지 포트 정보가 포함되도록 한다.
2) 취약한 패킷 필터링 장비는 첫 번째 단편에서 검사해야 할 정보(예: 목적지 포트)가 없으므로 이를 허용하고, 두 번째 단편은 '이미 첫 번째 단편이 허용되었다'라는 이유로 그대로 통과시킨다.
3) 대상 시스템에서는 두 단편이 재조합되어 결과적으로 공격자가 의도한 포트로 연결이 이루어진다.

답 Tiny fragment 공격

0283. ○ △ × 14.1회.기사

다음 설명하는 단편화를 이용한 DoS 공격 기법의 명칭은 무엇인가?

보기

헤더가 조작된 일련의 IP 패킷 조각(IP Fragment)들을 전송함으로써 공격이 이루어진다. 공격자가 패킷을 단편화할 때 정상적으로 하지 않고 데이터 일부가 겹치거나 일부 데이터를 포함하지 않고 다음 패킷으로 단편화하여 전송하면 수신자는 패킷 재조합을 수행할 때 부하나 오류가 발생하게 된다. 이 공격이 성공할 수 있는 원인은 윈도우 및 유닉스/리눅스 시스템의 IP 패킷 재조합 코드 버그에 있었으나 현재 대부분 시스템에서 이러한 공격에 대해 방어하고 있다.

정답 및 해설

Teardrop 공격은 IP 단편의 오프셋(Fragment Offset) 값을 비정상적으로 조작한 패킷을 전송하여, 대상 시스템이 IP 단편을 재조합하는 과정에서 오류가 발생하도록 만드는 서비스 거부 공격이다.
정상적인 IP 단편화에서는 각 단편의 오프셋 값이 정확하게 설정되어 문제없이 재조합되지만, Teardrop 공격은 중첩되거나 비연속적인 오프셋 값을 가진 IP 단편을 전송하여 대상 시스템의 재조합 모듈에서 버퍼 오버플로우 등 시스템 오류를 발생시킨다.

정답 Teardrop 공격

0284. ○ △ × 13.2회.산기

다음 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

서비스 거부(DoS) 공격 중 (A) 공격은 출발지를 목적지의 IP로 동일하게 만들어 전송함으로써 공격 대상 컴퓨터를 루프 상태에 빠트리는 공격을 말하며, (B) 공격은 공격자가 헤더의 조작된 일련의 IP 패킷 조각들을 전송함으로써 수신자가 패킷을 재조합하는 과정에서 부하가 걸리게 하는 공격 방법이다. (C) 공격은 아주 크게 만들어진 ICMP 패킷을 전송함으로써 공격 네트워크에 도달하는 동안 아주 작은 조각(Fragment)이 되어 공격 대상 시스템이 조각화된 패킷을 모두 처리해야 함으로써 성능을 떨어뜨리는 공격이다.

정답 및 해설

Ping of death 공격은 ping 명령을 이용하여 정상적인 크기보다 매우 큰 ICMP Echo Request 패킷(ICMP 패킷)을 전송함으로써 대상 시스템에 과부하나 오류를 유발하는 서비스 거부 공격으로 흔히 '죽음의 핑 날리기'라고도 한다. 공격 원리는 다음과 같다.

- 비정상적으로 큰 ICMP 패킷은 MTU를 초과하므로 네트워크 전송 과정에서 IP 단편화가 발생하여 하나의 패킷이 여러 개의 단편으로 분할되어 대상시스템에 전달된다.
- 대상 시스템은 다수의 IP 단편을 재조합하는 과정에서 과부하나 재조합 버퍼 오류에 의한 서비스 거부가 발생할 수 있다.

정답 (A) Land (B) Teardrop (C) Ping of death

0285. ○ △ × 20.1회.기사

다음 빈칸 (A), (B), (C)에 적절한 공격 명칭을 쓰시오.

보기

(A) : 출발지와 목적지 IP 주소를 공격 대상과 동일하게 설정하여 전송함으로써 공격 대상 컴퓨터를 루프 상태로 빠트리는 형태의 서비스 거부 공격
(B) : 출발지 IP 주소를 희생자의 IP 주소로 위조한 ICMP Echo Request 패킷을 증폭 네트워크로 브로드캐스트하여 다수의 ICMP Echo Reply 패킷이 희생자에게 전달되어 서비스 거부 상태를 유발하는 형태의 공격
(C) : 출발지 IP 주소를 위조한 다수의 TCP SYN 패킷을 희생자에게 전달하여 희생자의 TCP 연결 자원을 모두 소진시키는 형태의 서비스 거부 공격

정답 및 해설

1) Smurf 공격 : 출발지 IP를 희생자(Target) IP로 위조(IP 스푸핑)한 후 증폭(반사) 네트워크의 다이렉티드 브로드캐스트(Directed Broadcast) 주소로 ICMP Echo Request 패킷을 전송함으로써, 해당 네트워크의 모든 호스트가 ICMP Echo Reply 패킷을 희생자에게 보내도록 만들어 네트워크 대역폭을 소진시키는 서비스 거부 공격이다.
   - Directed Broadcast 방식 : 특정 원격 네트워크(서브넷)에 속한 모든 호스트에게 동시에 데이터를 전송하는 방식으로 해당 네트워크의 호스트 ID 비트를 모두 1로 설정한 주소(예: 172.30.3.255/24)를 사용한다.
   - Local Broadcast 방식 : 로컬 네트워크(동일 네트워크)에 속한 모든 호스트에게 동시에 데이터를 전송하는 방식으로 255.255.255.255로 예약된 주소를 사용한다.
2) TCP SYN Flooding 공격 : 출발지 IP 주소를 위조한(IP 스푸핑) 다수의 TCP SYN 패킷(연결 요청 패킷)을 대상 시스템에 전송하여 대상 시스템의 TCP 연결 자원(Backlog Queue)을 모두 소진시켜 정상 사용자의 연결 시도를 처리하지 못하도록 만드는 서비스 거부 공격이다.

정답 (A) Land 공격 (B) Smurf 공격 (C) TCP SYN Flooding 공격

0286. ○ △ × 15.2회.산기

다음 보기의 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

서비스 거부(DoS) 공격 중 Land 공격은 출발지와 목적지의 (A)을/를 공격 대상과 동일하게 만들어 전송함으로써 공격 대상 컴퓨터를 루프 상태에 빠트리는 공격을 말하며, Ping of death 공격은 공격자가 큰 용량의 (B) 패킷을 보내면 라우터가 패킷당 보낼 수 있는 크기인 (C)에 맞춰 패킷을 나누어 전송함으로써 대상 시스템의 재조합에 따른 부하를 초래한다.

정답 및 해설

정답 (A) IP 주소 (B) ICMP Echo Request(또는 ICMP) (C) MTU(Maximum Transmission Unit)

0287. ○ △ × 13.2회.기사 25.1회.기사

다음 보기의 빈칸 (A), (B), (C)에 적절한 용어를 쓰시오.

보기

(A) 공격이란 여러 호스트가 특정 공격 대상에게 대량의 ICMP Echo Reply를 보내게 하여 서비스 거부를 유발하는 공격이다. 이러한 공격에 대응하기 위해서는 다음과 같은 방법이 있다.

- 중간 매개자로 쓰이는 것을 막기 위해서 다른 네트워크로부터 자신의 네트워크로 들어오는 (B) 패킷을 막도록 라우터를 설정한다.
- 호스트는 IP Broadcast Address로 전송된 (C) 패킷에 대해 응답하지 않도록 시스템을 설정할 수 있다.

정답 및 해설

Smurf 공격은 출발지 IP를 희생자(Target) IP로 위조(IP 스푸핑)한 후 증폭(반사) 네트워크의 다이렉티드 브로드캐스트(Directed Broadcast) 주소로 ICMP Echo Request 패킷을 전송함으로써, 해당 네트워크의 모든 호스트가 ICMP Echo Reply 패킷을 희생자에게 보내도록 만들어 네트워크 대역폭을 소진시키는 서비스 거부 공격이다. 주요 대응 방법은 다음과 같다.

1) (증폭/반사 네트워크 관점)

- 증폭(반사) 네트워크로 악용되는 것을 방지하기 위해, 외부에서 유입되는 Directed Broadcast 패킷을 라우터(네트워크 장비)에서 차단한다.
- 시스템이 증폭(반사) 역할을 하지 않도록, Directed Broadcast로 수신되는 ICMP Echo Request 패킷에 대해 응답하지 않도록 설정한다.

2) (희생자 관점)

- 스머프 공격이 발생하면 단시간에 ICMP Echo Reply 패킷이 급증하므로, 임계치 기반의 이상 트래픽을 탐지하고 차단한다.

정답 (A) Smurf (B) Directed Broadcast (C) ICMP Echo Request

0288. ○ △ × 17.1회.기사

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

공격자가 공격 대상 IP로 출발지를 위장하여 ICMP (A) 패킷을 브로드캐스트로 발송하면 해당 네트워크 전체 호스트가 공격 대상 IP를 가진 호스트로 ICMP (B) 패킷을 전송하게 되므로 이를 수신한 시스템은 성능 문제가 발생할 수 있다. 이러한 (C)을/를 허용하게 되면 도스(DoS) 공격의 일종인 스머프(Smurf) 공격이 발생할 위협이 존재하게 된다. (C)를 막기 위해서는 라우터의 패킷 필터링 기능을 이용해야 한다.

정답 및 해설

스머프(Smurf) 공격에 의한 증폭/반사 네트워크로 악용되는 것을 방지하기 위해서는 외부에서 유입되는 Directed Broadcast 패킷을 라우터(네트워크 장비)에서 차단하도록 설정해야 한다. 시스코(Cisco) 라우터 설정 예를 살펴보면 다음과 같다.

```
Router> enable
  (단축: en) 사용자 모드에서 관리자 모드(enable 모드)로 전환
Router# configure terminal
  (단축: conf t) 관리자 모드에서 글로벌 설정 모드로 전환
Router(config)# interface FastEthernet0/0
  (단축: int f0/0) 글로벌 설정 모드에서 특정 인터페이스(FastEthernet0/0) 설정 모드로 전환
Router(config-if)# no ip directed-broadcast
  해당 인터페이스로 유입되는 Directed Broadcast 패킷을 차단하는 설정
```

정답 (A) Echo Request (B) Echo Reply (C) Directed Broadcast

관련지식

[알려진 DDoS 공격 도구]

1) 주요 도구

도구	날짜	공격방식
Trinoo	1999	UDP
TFN	1999	UDP, ICMP, TCP(SYN), Smurf
Stacheldracht	1999	UDP, ICMP, TCP(SYN), Smurf
TFN2K	2000	UDP, ICMP, TCP(SYN), Smurf
Shaft	2000	UDP, ICMP, TCP(SYN), Combo
Mstream	2000	UDP
Trinity	2000	UDP, Fragment, TCP(SYN, RST, Random Flag, ACK, NULL)

2) 주요 특징

(가) 트리누(Trinoo) 14.1회.산기

① 미네소타 대학, 솔라리스 2.x에서 최초 발견

② UDP Flooding DDoS 공격을 유발하는 데 사용되었으며 Attacker, Master, Zombie로 공격 네트워크를 구성

③ rpc.statd, rpc.cmds, rpc.ttdserverd 데몬의 취약점을 이용

④ 접속 포트

- Attacker -> Master : 27665/tcp
- Master -> Zombie : 27444/udp
- Zombie -> Master : 31335/udp
- Zombie -> Victim : udp 공격

(나) TFN(Tribe Flood Network)

① Trinoo처럼 rpc.statd, rpc.cmds, rpc.ttdserverd 데몬의 취약점을 이용

② Attacker가 Master에 명령 시 패스워드를 쓰지 않고 ICMP echo request 패킷에 명령어를 전송

③ TCP, UDP, ICMP 등을 복합적으로 사용하여 TCP Syn Flooding, UDP Flooding, ICMP Flooding, Smurf 공격 수행

(다) Stacheldracht

① Trinoo와 TFN의 발전된 형태로 TCP Syn Flooding, UDP Flooding, ICMP Flooding, Smurf 공격 등을 수행

② Master에 새로운 Agent가 자동으로 갱신되는 특징이 있다.

③ 접속 포트

- Attacker -> Master : 16660/tcp
- Master -> Zombie : 65000/tcp
- Zombie -> Master : ICMP Echo Reply
- Zombie -> Victim : TCP Syn, UDP Flooding, ICMP Flooding, Smurf

(라) TFN2K

① TFN의 발전된 형태로 통신에 특정 포트가 사용되지 않고 암호화되어 있음

② TCP, UDP, ICMP 등을 복합적으로 사용하여 TCP Syn Flooding, UDP Flooding, ICMP Flooding, Smurf 공격 등을 수행

③ UDP 패킷의 헤더는 정상적인 UDP 패킷보다 3byte 크고 TCP 패킷의 헤더 길이는 항상 0이다.

3) Trinoo 공격 실습

(가) Master 데몬을 통한 공격

① telnet을 통한 Master 데몬 접속(27665/udp)

- 원격 접속 시 패스워드 사용(password : betaalmostdone)

② bcast 명령 : Zombie PC 리스트 확인

③ dos 공격 대상 IP 명령 : 공격 대상 IP로 공격 개시(192.168.8.11)

④ mdie killme 명령 : 공격 중지

```
root@root:~/trinoo/master# netstat -an | grep 27665
tcp        0      0 0.0.0.0:27665           0.0.0.0:*               LISTEN
root@root:~/trinoo/master# telnet 127.0.0.1 27665
Trying 127.0.0.1...
Connected to 127.0.0.1.
Escape character is '^]'.
betaalmostdone
trinoo v1.07d2+f3+c..[rpm8d/cb4Sx/]

trinoo> bcast
Listing Bcasts.

192.168.8.10

End. 1 Bcasts total.
trinoo> dos 192.168.8.11
DoS: Packeting 192.168.8.11.
trinoo> mdie killme
mdie: Disabling Bcasts.
trinoo>
```

(나) 공격대상 패킷 캡처

① 단시간에 다량의 UDP 패킷이 발생하고 있음을 확인할 수 있다.(UDP Flooding)

No.	Time	Source	Destination	Protocol	Info
158498	6.971669	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:
158499	6.971681	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:
158500	6.971693	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:
158501	6.971704	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:
158502	6.971716	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:
158503	6.971728	192.168.8.10	192.168.8.11	T.38	UDP: UDPTLPacket Seq=00000 t30ind:

0289. ○△×

다음 보기에 열거한 공격 도구들은 어떤 공격을 위한 도구인지 쓰시오.

보기

Trinoo, TFN, Stacheldracht, Shaft, Trinity

정답 및 해설

Trinoo, TFN, Stacheldracht, Shaft, Trinity는 대표적인 분산 서비스 거부 공격 도구이다.

정답 분산 서비스 거부 공격(DDoS)

0290. ○△× 23.2회.기사

다음 보기에서 설명하는 도구의 이름을 쓰시오.

보기

Salvatore sanfilipp(살바토레 산필리포)가 만든 TCP/IP 프로토콜용 오픈소스 패킷 생성 및 분석 도구로 TCP, UDP, ICMP, IP 등 다양한 프로토콜의 패킷을, 옵션을 이용하여 손쉽게 생성할 수 있다. 네트워크 보안장비의 동작을 테스트하거나 디도스(DDoS) 모의훈련 시 모의 공격 패킷을 생성하기 위해 해당 도구가 주로 활용된다.

정답 및 해설

hping3 도구는 다양한 프로토콜(TCP, UDP, ICMP, IP 등)의 패킷을 간단한 옵션을 이용하여 생성할 수 있는 도구로 모의 공격 패킷을 생성하는 데 주로 사용된다. hping3를 이용하여 TCP SYN Flooding 공격 패킷 생성 예를 보면 아래와 같다.

```
┌──(root㉿kali)-[~]
└─# hping3 172.30.3.105 --rand-source -p 80 -S --flood
HPING 172.30.3.105 (eth0 172.30.3.105): S set, 40 headers + 0 data bytes
hping in flood mode, no replies will be shown
```

- 172.30.3.105 : 공격 대상(Target) 호스트 IP
- --rand-source : 패킷 생성 시마다 출발지 IP를 랜덤하게 설정
- -p 80 : 목적지 Port 번호를 80으로 지정
- -S(--syn) : SYN 제어비트 설정(프로토콜 미지정 시 기본 TCP 프로토콜 사용)
- --flood : 패킷 생성 속도를 의미하며 flood는 가능한 가장 빠른 속도로 패킷을 생성하라는 의미

정답 hping3

0291. ○△× 17.2회.산기

다음에 설명하는 봇넷(Botnet)의 종류(유형)를 쓰시오.

보기

- 분산형 명령/제어(Command/Control) 방식
- 참여 멤버(좀비/봇)가 모두 C&C(Command & Control) 서버 역할을 하므로 별도의 도메인과 C&C 서버가 불필요하다.
- 대표적인 봇넷으로 Storm, Peacomm 등이 있다.

정답 및 해설

봇넷의 명령/제어 방식은 '중앙 집중형 명령/제어 방식'과 '분산형 명령/제어 방식'으로 구분할 수 있다.

1) 중앙 집중형 명령/제어 방식
   - 공격자가 여러 도메인을 확보하여 C&C 서버(C2 서버)를 운영하고, 봇넷의 모든 좀비(봇)가 이 서버에 연결되어 명령을 수행하는 방식
   - 대표적인 봇넷 유형 : IRC 봇넷(Rbot 등), HTTP 봇넷(Robax 등)

2) 분산형 명령/제어 방식
   - 봇넷의 모든 좀비(봇)가 서로 공격자의 명령 정보를 전파하는 구조로, 중앙 관리를 위한 C&C 서버가 존재하지 않는다.
   - 대표적인 봇넷 유형 : P2P 봇넷(Storm, Peacomm 등)

정답 P2P 봇넷

0292. ○△×

다음 빈칸( )에 적절한 용어를 쓰시오.

보기

DNS ( ) 서비스는 악성 봇에 감염된 PC가 해커의 명령을 받기 위해 명령/제어 서버(C&C 서버)로 연결을 시도할 때, 이를 ( ) 서버로 우회시켜 더 이상 해커로부터 조종 명령을 받지 않도록 해주는 서비스이다. 악성 봇에 감염된 PC가 ( )이 적용된 DNS 서버에 질의를 요청하면, DNS 서버는 악성 봇 PC에 ( ) 서버의 IP 주소를 반환한다.

정답 및 해설

DNS 싱크홀(Sinkhole) 서비스는 악성 봇에 감염된 PC/디바이스가 C&C 서버로 접속을 시도할 때 실제 C&C 서버가 아닌 싱크홀 서버로 연결을 우회시켜 더 이상 공격자의 명령을 수신하지 못하도록 차단하는 보안 서비스이다.
또한 DNS 싱크홀 서비스는 C&C 서버 도메인뿐만 아니라 피싱(Phishing) 사이트 등 악성 도메인 목록을 함께 관리하여, 사용자가 해당 도메인으로 접속을 시도할 경우 이를 싱크홀 서버로 우회시켜 보안 위협을 사전에 차단하는 역할도 수행한다.

정답 싱크홀(Sinkhole)

0293. ○ △ × 21.2회.기사

다음 보기에서 설명하는 용어를 쓰시오.

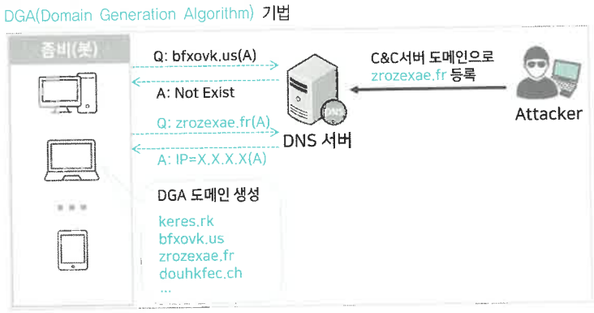
보기

봇넷을 구성하는 악성 봇(Bot) 또는 랜섬웨어 등의 악성코드(멀웨어)에 감염된 PC 또는 서버가 도메인명을 기반으로 C&C 서버(C2 서버)에 접속할 때 방화벽 등의 보안장비에 의해 도메인명이 탐지 및 차단되는 것을 우회하기 위한 기법의 하나이다.
특정한 규칙에 따라 C&C 서버의 임시 도메인명을 지속해서 동적 생성하는 기술로 다수의 도메인명이 무작위로 생성되기 때문에 보안장비를 통해 이를 식별하고 차단하기가 매우 어렵다.

정답 및 해설

공격자는 악성 봇(Bot) 또는 랜섬웨어 등의 악성코드에 감염된 PC 또는 서버가 C&C 서버(C2 서버)와 통신하는 과정에서 보안장비에 의해 탐지 및 차단되는 것을 우회하기 위해 다양한 기법을 사용한다. 대표적인 기법은 다음과 같다.

1) DGA(Domain Generation Algorithm) 기법



- 일정한 규칙(예: 시스템 날짜, 시드 값 등)에 따라 C&C 서버 도메인명을 동적으로 대량 생성하는 기법이다.
- 보안장비가 도메인 기반으로 C&C 서버를 탐지 · 차단하는 것을 우회하기 위해 사용된다.
- 공격자는 생성할 수 있는 도메인 중 일부만 실제로 등록하여 C&C 서버로 사용함으로써, 사전에 모든 도메인을 차단하는 것을 매우 어렵게 만든다.

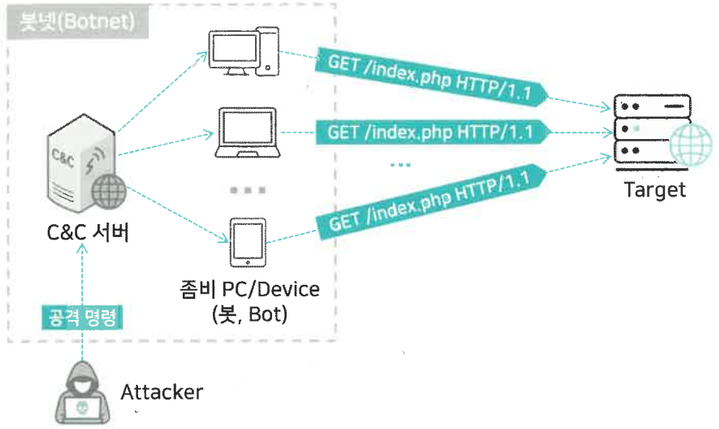
2) Fast Flux 기법
- 하나의 C&C 서버 도메인명에 대해 미리 확보한 다수의 C&C 서버 IP 주소를 할당하는 방식이다.
- DNS 캐시 서버에 저장되는 도메인 정보의 TTL(Time To Live) 값을 매우 짧게 설정하여, 질의 시마다 IP 주소가 빠르게 변경되도록 한다.
- 이로 인해 일부 IP가 탐지 · 차단되더라도 다른 IP를 통해 지속적으로 C&C 서버와 통신할 수 있다.

3) Domain Shadowing 기법
- 정상적으로 등록된 합법적인 도메인의 서브(하위) 도메인을 탈취하여 C&C 서버 도메인으로 사용하는 기법이다.
- 도메인 관리자의 계정 정보를 탈취한 후 다수의 서브 도메인을 은밀히 생성하는 방식으로 이루어진다.
- 주로 드라이브 바이 다운로드(DBD) 공격에서 악성코드 유포 경로를 은폐하기 위해 사용된다.

정답 DGA(Domain Generation Algorithm) 기법

0294. ○ △ × 15.2회.산기

다음은 DDoS(Distributed Denial of Service) 공격의 예로 여러 대의 좀비 PC/디바이스를 이용하여 웹 서버(Target)를 공격하는 상황을 보여주고 있다. 그림이 의미하는 공격 기법을 쓰시오.



정답 및 해설

HTTP GET Flooding 공격은 공격자가 동일한 동적 콘텐츠(URL)에 대한 HTTP GET 요청을 대량으로 발생시켜 대상 웹 서버가 이를 처리하기 위한 CPU, 메모리, DB Query 등의 자원을 과도하게 사용하도록 유도하고, 그 결과 정상적인 요청을 처리하지 못하게 만드는 서비스 거부 공격이다.

정답 HTTP GET Flooding 공격

0295. ○ △ × 13.1회.산기 24.2회.산기

다음에 설명하는 공격 기법을 구체적으로 쓰시오.

보기

DDoS 공격 중 HTTP 기반 응용 계층 공격으로, 기존의 네트워크 자원 소진형 공격에 비해 상대적으로 적은 패킷으로도 효과적인 공격이 가능한 기법이다.
출발지 IP 주소를 위조하지 않고 정상적인 TCP 3-Way Handshake를 수행한 후, 동일한 URL에 대한 HTTP GET 요청(예: GET /index.jsp HTTP/1.1)을 반복적으로 전송하여 웹 서버의 CPU 및 연결 자원 소진을 유발한다.
또는 로그인, 상품 조회와 같은 정상적인 HTTP 요청을 반복 전송하여 웹 서버 및 백엔드 데이터베이스 서버에 과부하를 발생시킨다.

정답 및 해설

정답 HTTP GET Flooding 공격

0296. ○△× 13.2회.산기 25.4회.산기

웹서버의 통신 내역을 pcap으로 수집한 후, ngrep 분석 도구를 이용하여 공격 행위를 분석하고자 한다. 다음 보기의 ngrep 명령을 통해 분석할 수 있는 디도스(DDoS) 공격 명칭을 쓰시오.

보기

```
ngrep -I webserver.pcap -tW byline | grep GET | sort | uniq -c | sort -rn
```

정답 및 해설

1) ngrep 도구는 네트워크 패킷을 대상으로 문자열 패턴 검색(grep과 유사)을 수행하는 패킷 분석 도구로 실시간 패킷 분석뿐만 아니라 패킷 덤프 파일(pcap 파일)을 이용한 분석도 가능하다. 주요 옵션은 다음과 같다.
   - -I : (대문자 I) 지정한 패킷 덤프 파일(pcap 파일)을 입력으로 사용하여 패킷 분석 수행
   - -t : 패킷 출력 시 타임스탬프를 함께 표시하여 시간 기반 분석이 가능하게 함
   - -W byline : 패킷 출력 형식을 지정하는 옵션으로 byline 형식은 LF(Line Feed) 제어 문자를 줄 바꿈 하여 출력한다.

2) 파이프라인 명령 및 수행 결과 예시

```
root# ngrep -I webserver.pcap -tW byline | grep GET | sort | uniq -c | sort -rn

8355   GET /index.php HTTP/1.1.
 136   GET /login.php HTTP/1.1.
  85   GET /board_list.php HTTP/1.1.
```

요청이 가장 많은 자원 순서로 정렬하여 요청 빈도 분석

- sort -rn 명령 : 공백을 구분자로 첫 번째 필드(기본 옵션, 요청 라인의 개수)를 숫자 기준(-n 옵션), 역순(-r 옵션, 내림차순)으로 정렬하는 명령
- grep GET 명령 : GET 패턴이 포함된 행(요청 라인 정보)만 필터링
- sort 명령 : grep 명령으로 필터링된 요청 라인 행을 문자 기준 오름차순 정렬(기본 옵션)하는 명령으로 uniq 명령이 중복 여부를 판단할 수 있도록 정렬을 선행함
- uniq -c 명령 : 정렬된 결과에서 연속된 중복 행을 하나로 묶어 출력하며, 각 행의 중복 건수(-c 옵션)를 함께 표시하는 명령
- sort -rn 명령 : 공백을 구분자로 첫 번째 필드(중복 건수)를 숫자 기준(-n 옵션), 역순(-r 옵션, 내림차순)으로 정렬하는 명령

3) (정리) 위 명령을 수행하면 HTTP GET 방식(메서드)으로 요청한 자원과 요청 건수를 내림차순(건수 기준)으로 확인할 수 있다. 과도한 GET 요청이 발생했다면 이는 HTTP GET Flooding 공격으로 판단할 수 있다.

정답 HTTP GET Flooding 공격

0297. ○△× 15.1회.산기

다음 그림처럼 동일한 IP에서 웹서버로 짧은 시간 동안 (A) 메서드를 이용한 요청을 하는데, 그림에 나타난 공격은 (B) 공격의 한 방법으로 (C) 공격이라 한다. 빈칸( )에 적절한 용어를 쓰시오.

No.	Time	Source	SrcPort	Destination	DstPort	Protocol	Info
46	174.607	10.10.1.200	43265	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
54	174.623	10.10.1.200	57605	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
62	174.628	10.10.1.200	57961	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
70	174.630	10.10.1.200	41059	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
78	174.632	10.10.1.200	41635	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
86	174.634	10.10.1.200	39179	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
94	174.636	10.10.1.200	46361	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
102	174.637	10.10.1.200	40313	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
110	174.639	10.10.1.200	33497	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
118	174.640	10.10.1.200	54447	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
126	174.641	10.10.1.200	52641	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
134	174.643	10.10.1.200	58959	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
142	174.644	10.10.1.200	38785	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
150	174.645	10.10.1.200	44773	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
158	174.647	10.10.1.200	34359	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
166	174.648	10.10.1.200	41367	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
174	174.649	10.10.1.200	35199	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
182	174.651	10.10.1.200	55167	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
190	174.652	10.10.1.200	39535	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1
198	174.653	10.10.1.200	36893	172.30.1.100	80	HTTP	GET /index.php HTTP/1.1

정답 및 해설

Time 필드를 보면 매우 짧은 시간 동안 동일한 출발지 IP 주소(10.10.1.200)에서 공격 대상 웹 서버(172.30.1.100)로 동일한 자원(/index.php)에 대한 다수의 HTTP GET 요청이 반복적으로 발생하고 있음을 확인할 수 있다.
이는 정상적인 TCP 연결 설정(3-Way Handshake) 이후 동일한 클라이언트가 GET 요청을 대량으로 전송하여 웹 서버의 CPU 및 연결 자원을 소진시키는 공격 형태로, HTTP GET Flooding 기반의 DoS(서비스 거부) 공격으로 판단할 수 있다.

정답 (A) GET (B) DOS(서비스 거부) (C) HTTP GET Flooding

0298. ○ △ × 15.1회.기사

알기사 서버 관리자는 Telnet 서버의 전송속도가 느려졌다는 보고를 받고 서버의 상태를 점검하던 중 아래 그림과 같은 결과를 얻었다. 문제의 원인이 어떠한 공격 때문인지 쓰시오.

(Telnet 서버의 주소는 172.30.1.1000이며, netstat -ant 명령을 수행한 결과이다)

```
[root@Fedora11 ~]# netstat -ant
Active Internet connections (servers and established)
Proto  Recv-Q  Send-Q  Local Address        Foreign Address        State
tcp        0       0   172.30.1.100:23      211.65.51.100:2274     SYN_RECV
tcp        0       0   172.30.1.100:23      51.0.14.36:2275        SYN_RECV
tcp        0       0   172.30.1.100:23      70.144.138.30:2326     SYN_RECV
tcp        0       0   172.30.1.100:23      25.25.234.203:2287     SYN_RECV
tcp        0       0   172.30.1.100:23      157.234.51.93:2297     SYN_RECV
tcp        0       0   172.30.1.100:23      191.138.123.220:2270   SYN_RECV
tcp        0       0   172.30.1.100:23      219.168.107.70:2283    SYN_RECV
tcp        0       0   172.30.1.100:23      251.24.242.177:2272    SYN_RECV
tcp        0       0   172.30.1.100:23      46.57.234.107:2264     SYN_RECV
tcp        0       0   172.30.1.100:23      167.229.36.173:2314    SYN_RECV
tcp        0       0   172.30.1.100:23      76.231.250.59:2281     SYN_RECV
tcp        0       0   172.30.1.100:23      206.155.57.86:2293     SYN_RECV
tcp        0       0   172.30.1.100:23      21.24.13.227:2268      SYN_RECV
tcp        0       0   172.30.1.100:23      173.158.232.17:2256    SYN_RECV
```

정답 및 해설

정상적인 TCP 연결에서는 클라이언트의 SYN 패킷에 대해 서버가 SYN/ACK로 응답한 후, 클라이언트의 ACK 응답을 받아 연결 설정이 완료된다. 그러나 제시된 netstat -ant 결과를 보면 Telnet 서버(172.30.1.100:23)에 대해 다수의 TCP 연결이 SYN_RECV(SYN_RECEIVED) 상태로 유지되고 있으며, 이는 SYN/ACK에 대한 정상적인 ACK 응답이 도착하지 않았음을 의미한다.

TCP SYN Flooding 공격의 경우 공격자는 출발지 IP 주소를 위조(IP 스푸핑)한 다수의 SYN 패킷을 전송하여 서버가 연결 설정을 완료하지 못한 채 대기 상태의 소켓을 다량으로 유지하도록 유도한다. 이로 인해 서버의 TCP 연결 자원(Backlog Queue)이 고갈되고, 정상적인 Telnet 서비스 접속이 지연되거나 불가능해진다.

따라서 본 문제의 원인은 TCP SYN Flooding 공격으로 판단할 수 있다.

정답 TCP SYN Flooding 공격

0299. ○ △ × 14.1회.기사

다음 그림은 특정 서버로 유입되는 트래픽을 패킷 수집/분석용 프로그램을 이용하여 캡처한 결과이다. 어떠한 공격으로 의심되는가?

No.	Time	Source	Destination	Proto	Info
10	4.737	197.126.68.138	172.30.1.100	TCP	2330 → 443 [SYN] Seq=1791992058
11	4.737	172.30.1.100	197.126.68.138	TCP	443 → 2330 [SYN, ACK] Seq=245333947 Ack=1791992059
12	4.841	33.209.230.21	172.30.1.100	TCP	2331 → 443 [SYN] Seq=2125693144
13	4.841	172.30.1.100	33.209.230.21	TCP	443 → 2331 [SYN, ACK] Seq=252291533 Ack=2125693145
14	4.952	105.99.192.92	172.30.1.100	TCP	2332 → 443 [SYN] Seq=1165955683
15	4.952	172.30.1.100	105.99.192.92	TCP	443 → 2332 [SYN, ACK] Seq=251441596 Ack=1165955684
16	5.058	206.92.2.134	172.30.1.100	TCP	2333 → 443 [SYN] Seq=325172159
17	5.058	172.30.1.100	206.92.2.134	TCP	443 → 2333 [SYN, ACK] Seq=250764414 Ack=325172160
18	5.160	14.26.131.209	172.30.1.100	TCP	2334 → 443 [SYN] Seq=1424285422
19	5.160	172.30.1.100	14.26.131.209	TCP	443 → 2334 [SYN, ACK] Seq=259269374 Ack=1424285423
20	5.260	196.178.18.30	172.30.1.100	TCP	2335 → 443 [SYN] Seq=2007668141
21	5.260	172.30.1.100	196.178.18.30	TCP	443 → 2335 [SYN, ACK] Seq=262241845 Ack=2007668142
22	5.368	126.78.92.161	172.30.1.100	TCP	2336 → 443 [SYN] Seq=1869272795
23	5.368	172.30.1.100	126.78.92.161	TCP	443 → 2336 [SYN, ACK] Seq=256502984 Ack=1869272796
24	5.476	68.30.230.127	172.30.1.100	TCP	2337 → 443 [SYN] Seq=1203097608
25	5.476	172.30.1.100	68.30.230.127	TCP	443 → 2337 [SYN, ACK] Seq=252658736 Ack=1203097609
26	5.584	100.196.103.132	172.30.1.100	TCP	2338 → 443 [SYN] Seq=842717264
27	5.584	172.30.1.100	100.196.103.132	TCP	443 → 2338 [SYN, ACK] Seq=258833789 Ack=842717265
28	5.691	83.231.242.80	172.30.1.100	TCP	2339 → 443 [SYN] Seq=1699422948
29	5.691	172.30.1.100	83.231.242.80	TCP	443 → 2339 [SYN, ACK] Seq=253143358 Ack=1699422949

정답 및 해설

패킷 캡처 결과를 보면 다수의 서로 다른 출발지 IP 주소로부터 TCP SYN 패킷이 지속적으로 유입되고 있으며, 이에 대해 서버(172.30.1.100)는 SYN/ACK 패킷으로 응답하고 있다. 그러나 이후 해당 클라이언트로부터 정상적인 ACK 응답이 수신되지 않아 TCP 연결 설정(3-Way Handshake)이 완료되지 않고 있다.

이는 공격자가 출발지 IP 주소를 위조(IP 스푸핑)한 상태로 다수의 SYN 패킷을 전송하여 서버가 연결 설정을 완료하지 못한 채 대기 상태의 TCP 연결 자원을 지속적으로 점유하도록 만드는 공격 형태이다. 이로 인해 서버의 TCP 연결 자원(Backlog Queue)이 고갈되어 정상적인 서비스 제공이 어려워진다.

따라서 제시된 트래픽은 TCP SYN Flooding 공격으로 판단할 수 있다.

정답 TCP SYN Flooding 공격

0300. ○ △ × 16.2회.산기 25.1회.산기

다음 설명에 해당하는 공격 유형을 쓰시오.

보기

이 공격은 TCP 연결 설정 과정의 구조적 취약점을 이용한 공격이다. TCP 3-Way Handshake 과정에서 Half-Open 연결 상태가 발생할 수 있다는 점을 악용하여 Half-Open 상태의 연결을 과도하게 생성함으로써, 목표 시스템이 외부로부터의 정상적인 연결 요청을 더 이상 수용하지 못하고 서비스 불가 상태에 이르게 된다.

정답 및 해설

TCP SYN Flooding 공격은 TCP 연결 설정 과정(3-Way Handshake)의 구조적 취약점을 이용한 공격이다.
TCP 연결 설정 과정에서 클라이언트를 인증하지 않는 구조적 취약점(요청한 클라이언트의 IP가 유효한지 검증하지 않는 취약점)을 이용하여, 출발지 IP를 위조한 다수의 SYN 요청을 보내고 그 결과 서버에 과도한 Half-Open 연결 상태가 지속된다.
이에 따라 TCP 연결 자원(Backlog Queue)이 고갈되어 정상적인 연결 요청을 처리할 수 없게 된다.

- Half-Open 연결 상태 : TCP 연결을 요청한 상대방과 연결 설정이 진행 중인 상태(연결 설정이 완료되지 않은 상태)를 의미한다.

정답 TCP SYN Flooding 공격

0301. ○ △ × 20.1회.산기

다음 보기의 빈칸( )에 적절한 용어를 쓰시오.

보기

( ) 공격은 서버의 동시 연결 대기 사용자 공간이 제한되어 있다는 점을 이용한 공격 기법으로, 실제로 존재하지 않는 클라이언트가 다수의 연결 요청을 보낸 것처럼 위장하여 서버별로 한정된 접속 가능한 공간을 모두 소진시킨다. 그 결과 정상적인 사용자가 서버에 접속하지 못해 서비스 거부 상태가 발생한다.

정답 및 해설

TCP SYN Flooding 공격은 출발지 IP를 위조한 다수의 SYN 요청을 전송하여 공격 대상 서버의 제한된 연결 대기 공간(Backlog Queue)을 소진시키는 공격이다. 공격자는 3-Way Handshake를 완료하지 않아 서버에 Half-Open 연결 상태를 지속적으로 유지시키며, 그 결과 정상적인 연결 요청을 더 이상 처리하지 못하게 된다.

정답 TCP SYN Flooding

0302. ○ △ × 18.2회.산기

다음은 TCP SYN Flooding 공격에 대한 설명이다. 빈칸( )에 적절한 용어를 쓰시오.

보기

TCP SYN Flooding 공격은 TCP 연결 설정 과정(3-Way Handshake)의 구조적 취약점을 이용한 공격이다. 공격자가 대상 서버의 특정 포트로 TCP 연결 설정을 위한 (A) 플래그 패킷을 전송하면, 대상 서버는 (A)+(B) 플래그 패킷으로 응답한다.
정상적인 클라이언트라면 (C) 플래그 패킷으로 응답하여 연결을 완료하지만, 공격자는 응답을 보내지 않아 Half-Open 상태를 유지한다. 그 결과 대상 서버의 TCP 연결 자원이 지속적으로 소모된다.

정답 및 해설

정답 (A) SYN (B) ACK (C) ACK

0303. ○ △ × 18.1회.기사

HTTP 프로토콜의 취약점을 이용한 공격으로, 다수의 HTTP 요청 시 요청 헤더의 끝을 의미하는 개행문자(CRLF: Carriage Return+Line Feed) 연속 2번을 전송하지 않고 불필요한 헤더 정보를 천천히 지속해서 전송하여 대상 웹 서버와의 연결 상태를 장시간 지속시킴으로써 연결 자원을 모두 소진시키는 형태의 서비스 거부(DoS) 공격을 무엇이라 하는가?

정답 및 해설

Slow 계열 서비스 거부(DoS) 공격은 HTTP 프로토콜의 취약점을 이용한 공격으로, 소량의 HTTP 요청 트래픽만으로 웹 서버와의 연결을 장시간 점유하여 동시 연결 자원을 고갈시킨다. 공격 유형별 특징은 다음과 같다.

1) Slow HTTP Header 공격(Slowloris 공격)
   - 다수의 HTTP 요청을 전송하면서 요청 헤더의 끝을 의미하는 개행문자(CRLF) 연속 2번을 보내지 않고, 의미 없는 헤더만 매우 느린 속도로 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 공격
2) Slow HTTP POST 공격(RUDY 공격)
   - 다수의 HTTP POST 요청을 전송하면서 Content-Length 헤더 값을 실제 전송할 데이터 크기보다 매우 크게 설정한 후, 매우 작은 데이터를 천천히 지속적으로 전송하여 웹 서버와의 연결을 장시간 유지시키는 공격
3) Slow HTTP Read 공격
   - 다수의 HTTP 요청에 대한 서버 응답 과정에서 클라이언트가 TCP 윈도우 크기(Window Size)를 0으로 설정한 Zero Window 패킷을 지속적으로 전송하여 HTTP 응답 데이터의 수신을 지연시키는 공격

정답 Slow HTTP Header 공격(Slowloris 공격)